정보보호론

강의개요

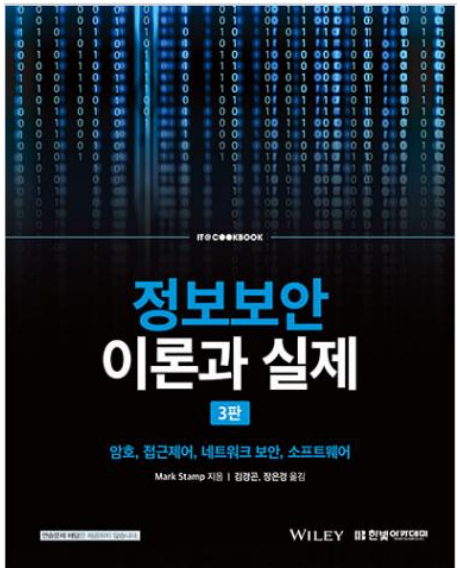
Venture 1st
호서대학교

강의개요

- 강의목표
  - 정보보호의 3대 목표인 **기밀성, 무결성, 가용성**을 제공할 수 있는 다양한 암호 알고리즘에 대한 기본적인 이해를 바탕으로, 시스템 보안 및 네트워크 보안 시스템을 구성하는 정보보호 요소 기술에 대한 이해를 목표로 한다.

- 교재 : **정보보안 이론과 실제**, Mark Stamp 저,(한빛아카데미)
  - 부교재 : 현대암호학 제 7판, 원동호 저(도서출판 그린)

- 담당교수 : 오수현(제2공학관 405호)



강의개요

➢ 성적 평가 방법

- 상대평가 : A(50%), B(30%), C이하(20%)
- 2개 분반 합반하여 성적 산출

➢ 성적 산출 기준 : 중간(30%) + 기말(30%) + 출석(20%) + 과제/퀴즈(20%)

등 급	평가점수 (절대평가)	상대평가비율		
		기준	최대허용비율	
			등급간	A+B
A (A+ , AO)	A+ : 95이상 A0 : 90이상 ~ 95미만	35% 이하	50% 이하	90% 이하
B (B+ , BO)	B+ : 85이상 ~ 90미만 B0 : 80이상 ~ 85미만	45% 이하	–	
C 이하	C+ : 75이상 ~ 80미만 C0 : 70이상 ~ 75미만 D+ : 65이상 ~ 70미만 D0 : 60이상 ~ 65미만 F : 60미만	20% 이상	–	10% 이상

강의개요

➢ 강의 방식 : 하이브리드 강의

- 1,2차시 : 대면강의
- 3차시 : 비대면 강의
  - 강의영상을 정해진 기간 내에 학습하고, 과제 제출을 완료해야 출석 인정

➢ 휴/보강 계획

- 공휴일, 학교 행사 등의 이유로 휴강 시 비대면 강의로 보강
- 강의 영상 콘텐츠 학습 및 과제 제출(실시간 강의는 진행하지 않음)

➢ 기타

- 수업에 관한 공지사항 확인 및 강의자료 다운로드는 LMS 이용
- 질문은 LMS "쪽지" 기능, "강좌 Q&A" 나 이메일(shoh@hoseo.edu) 이용
  - 쪽지는 평일 오전 9시~ 오후 6시에 이용!!!

교재 내용

I부
암호
1장
개요
2장
암호 기초
3장
대칭키 암호
4장
공개키 암호
5장
암호화 해시 함수
II부
접근제어
6장
인증
7장
인가
III부
네트워크 보안
8장
네트워크 보안 기본
9장
단순 인증 프로토콜
10장
실제 보안 프로토콜
IV부
소프트웨어
11장
소프트웨어 결함과 멀웨어
12장
소프트웨어 비보안성

주차별 강의 내용

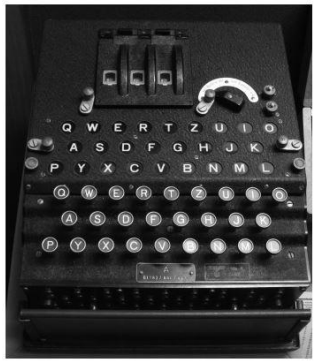
주	강의 내용	비고
1	강의 소개 및 정보보호 개요	
2	Chap.1 개요 / Chap.2 암호 기초	
3	Chap.3 대칭키 암호(1)	DES, SEED 세부 내용
4	Chap.3 대칭키 암호(2)	AES 세부 내용
5	Chap.3 대칭키 암호(3)	블록 암호 시스템의 활용
6	Chap.4 공개키 암호(1)	RSA, Diffie-Hellman
7	Chap.4 공개키 암호(2)	
8	Chap.4 공개키 암호(3)	중간고사
9	Chap.5 암호화 해시 함수 및 기타(1)	
10	Chap.5 암호화 해시 함수 및 기타(1)	SHA 세부 내용
11	Chap.6 인증	메시지 인증 추가
12	Chap.9 단순 인증 프로토콜	
13	전자서명	부교재 참고
14	Chap.7 인가	
15	개인정보보호	기말고사

정보보호 개요

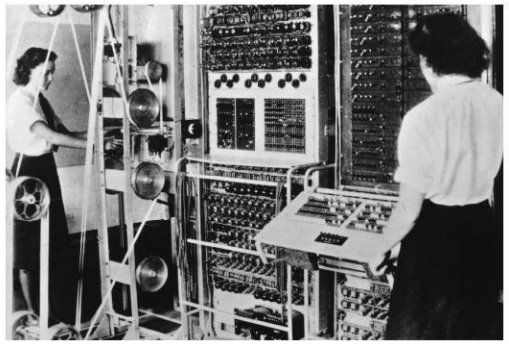
1. 정보 보안의 역사

➢ 1950년대 이전

- 에니그마(Enigma)와 콜로서스(Colossus)
  - 1918년 폴란드의 암호 보안 전문가들이 개발한 평문 메시지를 암호화된 메시지로 변환하는 장치
  - 은행의 통신 보안 강화를 위해 개발됐지만 제2차 세계대전에서 독일군의 군사 통신 보안용으로 사용
  - 문자판의 키 하나를 누르면 나란히 원판 3개가 회전하면서 복잡한 암호가 만들어짐
  - 1943년 영국의 앨런 튜링이 만든 최초의 컴퓨터인 콜로서스를 이용하여 에니그마 해독
  - 형태가 변형되어 1970년대까지 상업적 보안 통신용으로 사용됨



[에니그마와 에니그마를 사용하는 독일군]



[최초의 컴퓨터 콜로서스]

1. 정보 보안의 역사

➢ 1960~1970년대

- 최초의 **컴퓨터 연동망 ARPA**
  - 1967년 미국 국방부는 관련 기관 사이의 정보 공유를 지원하는 ARPA(Advanced Research Projects Agency) 프로젝트를 통해 컴퓨터 연결망 개발
  - **ARPAnet**이라고 불린 이 연동망은 오늘날 **인터넷의 시작**

- **유닉스** 운영체제의 개발
  - 1969년 켄 톰프슨과 데니스 리치는 운영체제인 유닉스(UNIX) 개발
  - 개발자 툴 및 컴파일러에 접근하기가 쉽고 여러 사용자가 동시에 사용할 수 있다는 특성

- 최초의 **이메일** 전송
  - 1971년 레이먼드 토밀슨이 최초의 이메일 프로그램 개발
  - 64노드의 알파넷에서 @을 사용한 최초의 이메일 발송(“qwertyuiop” 전송)

1. 정보 보안의 역사

➢ 1960~1970년대

- **마이크로소프트 설립**
  - 1974년 MITS라는 회사가 세계 최초로 조립식 개인용 컴퓨터 앨테어 8800를 만들어 판매
  - 앨테어 8800은 조립식이며 소프트웨어도 따로 없었고 토글 스위치의 불빛을 보고 결과를 해독하는 형식
  - 1975년 빌 게이츠는 폴 앨런과 앨테어 8800에서 동작하는 앨테어 베이직을 작성하기로함
  - 같은 해 4월 하버드 대학 자퇴 후 마이크로소프트 설립

- **애플 컴퓨터의 탄생**
  - 1979년 애플 컴퓨터가 스티브 워즈니악과 스티브 잡스에 의해 탄생
  - 오늘날의 PC와 비슷한 모습의 애플 컴퓨터는 그 당시에 666달러 66센트라는 가격에 판매
  - 데스크톱 PC가 보급과 함께 일부 사용자들이 일반 PC 통신 하드웨어를 사용하여 원격 시스템 해킹 시도

1. 정보 보안의 역사

➢ 1980~1990년대

- **네트워크 해킹의 시작**
  - 1980년대 초 네트워크 해커라는 개념이 처음 탄생
  - 대표적인 네트워크 해킹 사건 발생

414 Gang	Captain Zap
1983년 해커 그룹 '414 Private'가 암 센터와 로스알라모스 국립 연구소를 포함해 60개의 컴퓨터 시스템에 침입 → 중요 파일을 삭제함	1981년 'Captain Zap'이라는 별명을 가진 이안 머핀(Ian Arthur Murph)이 AT&T의 컴퓨터 시스템에 침입 → 전화 요금 조작

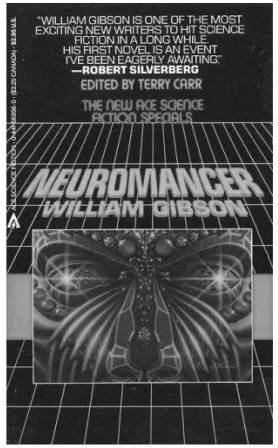
- **정보 권리 논쟁의 시작**
  - 1981년 독일의 전설적인 해커 그룹인 카오스 컴퓨터 클럽(CCC) 결성
  - 카오스 컴퓨터 클럽의 설립 목표는 **정보에 대한 자유로운 접근 권리**를 공식적으로 주장
  - 카오스 클럽은 소식지 창간호에서 설립 목표를 다음과 같이 규정
    - 정보 사회로 발전하려면 전 세계와 자유로운 커뮤니케이션을 가능케 하는 새로운 인권이 필요하다.
    - 인간 사회 및 개인에게 기술적 영향을 미치는 정보 교류에서 국경이 사라져야 한다.
    - 우리는 지식과 정보의 창조에 이바지할 것이다.

1. 정보 보안의 역사

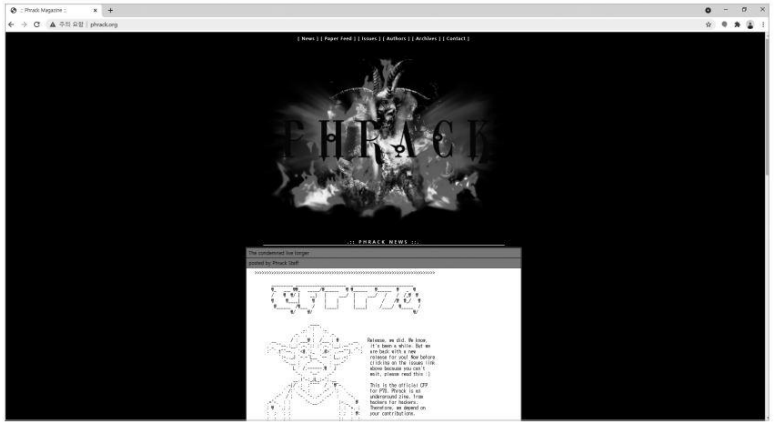
➢ 1980~1990년대

▪ 해킹 문화의 등장

- 1983년 영화 '워 게임즈(War Games)' 개봉 : 해커를 소재로 한 최초의 영화
- 1985년 해킹 잡지 '프랙(Phrack)' 창간
- 1985년 7명의 미국 소년에 의한 미 국방부 컴퓨터 해킹 : 극비 군사통신 데이터 획득
- 1986년 해킹 잡지 '2600' 정기 출판
- 1986년 컴퓨터 범죄 관련 최초의 처벌 규정 제정 : 컴퓨터 사기와 오용에 관한 조항



[영화 "War Games "] [소설 "뉴로맨서"]



[프랙 홈페이지(www.phrack.org)]

1. 정보 보안의 역사

➢ 1980~1990년대

- 해커의 등장
  - 1980년대에 해킹이 발전하면서 역사적으로 유명한 해커들이 본격적으로 등장
    - 1986년 구소련 KGB로부터 자금을 지원받는 서독 해커들이 300여 기관에 불법적인 접근을 시도하고 군사 기밀 정보를 탈취
    - 1987년에는 케빈 미트닉이 컴퓨터 개발·판매 회사인 산타크루스 오퍼레이션의 시스템에 침입
    - 1988년 11월 22일 코넬대학 대학원생이었던 로버트 모리스는 웜 바이러스를 구동하여 미국 전역에 피해를 끼침
    - 로이드 블랭켄십은 사이버 갱단 MoD의 멤버로 해킹과 프리킹에 관한 문서를 주고받는 장소인 Elite 보드를 운영 – 해커 선언문(The conscience of a Hacker) 발표

1. 정보 보안의 역사

➢ 1980~1990년대

- **데프콘(DEF CON) 해킹 대회 개최**
  - 최초의 해킹 대회인 '데프콘'이 1990년 라스베이거스에서 개최
  - 데프콘 해킹 대회는 매년 개최되며, 팀 단위로 예선을 거쳐 여덟 팀이 라스베이거스에서 본선 진행
  - 자신의 팀을 보호하면서 상대 팀을 공격하여 상대 시스템을 많이 해킹한 팀이 승리

- **해킹 도구의 개발**
  - 1994년 인터넷 브라우저인 "넷스케이프"가 개발되어 웹 정보에 대한 접근이 가능해짐
  - 해커들은 자신의 노하우, 해킹 정보와 해킹 툴을 웹에 공개
  - 일부 사용자들은 해킹 툴을 사용하여 개인 정보를 캐기도 하고 은행 컴퓨터의 계좌 정보 변조 시도
  - 언론은 이들을 해커라 부르기 시작

해크(Hack)의 의미

- 1948년도 설립된 메사추세츠 공과대학(MIT)의 모형 기차 제작 동아리인 TMRC (Tech Model Railroad Club)에서 '전기 기차, 트랙, 스위치를 보다 빠르게 조작하다'라는 의미로 사용
- 기차를 잘 움직이도록 컴퓨터를 연구하는 과정에서 본래의 목적이 점차 컴퓨터 자체를 연구하고 프로그램을 개발하는 쪽으로 변화함

1. 정보 보안의 역사

➢ 1980~1990년대

- 아메리카온라인 해킹
  - 1997년에 아메리카온라인(AOL) 침입만을 목적으로 고안된 무료 해킹 툴인 AOHell이 공개
  - AOHell은 초보 해커와 스크립트 키드가 사용하도록 개발된 것
  - 이후 며칠 동안 초보 해커들이 악용하여 미국 내 수백만 명의 온라인 사용자가 대용량 메일 폭탄 공격을 받음

- 트로이 목마 "백 오리피스"
  - 1998년에는 'CDC(Cult of the Dead Cow)'라는 해킹 그룹이 데프콘 해킹 대회에서 트로이 목마 프로그램인 '백 오리피스(Back Orifice)'를 발표
    - 원격에서 상대방의 시스템을 제어할 수 있는 해킹 도구
  - Tae Analyzer라는 이스라엘의 10대 해커가 미국 펜타곤의 시스템에 침투해서 소프트웨어를 훔쳐낸 사건이 발생

1. 정보 보안의 역사

➢ 2000년대 이후

- **분산 서비스 거부 공격 (DDoS)**
  - 2000년 2월 인터넷에서 트래픽이 많은 몇 개 사이트에 분산 서비스 거부(DDoS) 공격 발생
  - 이로 인해 야후, CNN, 아마존 등의 사이트가 ICMP 패킷을 이용한 스머프 공격으로 몇 시간 동안 마비
    - 네트워크를 스캔한 후 취약한 서버에 trojans라는 클라이언트 프로그램을 설치하여 정해진 시간에 목표 사이트에 수많은 패킷을 전송함으로써 사이트가 다운되도록 하는 공격

- **웜과 바이러스**
  - 2000년에는 러브 버그 바이러스가 등장하여 87억 5,000만 달러의 경제적 손실을 입힘
    - 바이러스 메일에는 “ILOVEYOU”라는 제목에 “발송드린 첨부의 LOVELETTER를 확인 부탁드립니다”라는 내용의 본문 메시지와 ‘LOVELETTER.TXT.VBS’라는 파일이 첨부
    - 첨부 파일에 접근하면 다른 이메일 계정으로 메일이 복제 및 전송
  - 2003년 1월 마이크로소프트의 MS-SQL 2000 서버를 공격하는 슬래머 웜이 전국 네트워크를 마비시킨 사건 발생
  - 2004년에는 베이글 웜, 마이둠 웜, 넷스카이 웜이라는 웜 삼총사가 등장

1. 정보 보안의 역사

➢ 2000년대 이후

- **개인 정보 유출과 도용**
  - 2005년~2006년 사이에 우리나라에서 주민등록번호 수십만 개가 유출되어 개인 정보가 무단 도용 사건 발생
  - 사이버테러대응센터에서 접속 IP를 분석해보니 중국에서 직접 접속한 경우, 국내 사설망 등을 통해 접속한 경우, 해킹으로 중간 경유지를 이용한 경우 등이 원인으로 밝혀짐
  - 2005년 11월에는 금융 정보를 이용하여 은행 계좌에서 잔고를 인출한 사건 발생
  - 국내에서는 **2011년 "개인정보보호법 " 제정 및 개인정보보호위원회 출범**

- **전자 상거래 보안 문제 발생**
  - 2006년 7월에는 안심클릭의 허점을 이용한 해킹 사기 사건이 발생
    - 범인들은 해킹으로 타인의 신용카드 번호를 입수한 후, 인터넷에서 이루어지는 신용카드 결제 방식의 제도적· 기술적 취약점을 이용하여 물품을 대신 결제하고 현금을 돌려받아 수억 원을 인출
    - 대부분의 신용카드 사용자들이 일반 사이트,쇼핑몰, 카드사 사이트의 접속 아이디와 비밀 번호를 동일한 점에 착안한 범죄

1. 정보 보안의 역사

➢ 2000년대 이후

- 2006년 3월에는 국내 대형 포털 사이트의 정보 검색 순위를 조작한 인터넷 광고 대행 업체의 대표가 입건
  - 자체 개발한 프로그램을 이용하여 750개 회사의 홈페이지 주소를 자동으로 클릭하게 만들어 정보 검색 순위 조작
- 2007년 공인인증서 유출로 인한 시중 은행 불법 유출 사건 발생

▪ APT(Advanced Persistent Threat) 공격의 등장

- 새로운 기술을 이용하여 다양하게 진화하는 공격으로 단시간 내에 공격이 이루어지는 것이 아니라, 짧게는 수일에서 길게는 수년 단위로 공격이 지속되는 공격 유형
- 2008년 해커 8명으로 구성된 캐시어가 영국 RBS 은행의 월드페이 시스템에 침입하여 복제 카드를 제작
  - 신용카드의 한도를 올리고 12시간 동안 세계 49개 도시의 2,100개 ATM 기기에서 약 950만 달러를 인출
  - 이 해킹 사건을 최초의 APT(지능적 지속 위협) 공격으로 흔히 언급

1. 정보 보안의 역사

➢ 2000년대 이후

- 농협 사이버 테러
  - 2011년 4월 대규모 데이터 삭제로 농협의 전산 시스템이 멈추는 사건이 발생
  - 이 사건은 국내 기업의 보안 인식 자체를 바꿔 놓는 계기가 됨

- 스마트폰 해킹
  - 대표적인 스마트폰 운영체제인 애플의 iOS와 구글의 안드로이드는 모두 유닉스(리눅스)와 유사
  - 리눅스에 기반을 둔 안드로이드에는 리눅스 해킹 툴을 비교적 쉽게 설치할 수 있음
  - 스마트폰은 긴 시간 동안 전원 공급이 가능하고 와이파이, 3G 망, LTE 망도 이용 가능한 최고의 해킹 도구
  - 스마트 폰을 활용한 해킹 공격을 통해 스마트 폰에 저장된 개인정보 탈취

- 가상 화폐 해킹 사건 발생

표 1-1 가상 화폐 해킹 사례

발생 시기	거래소 명	피해 원인	피해 규모
2019년 11월	업비트	핫월렛 해킹	580억 원
2018년 6월	빗썸	이메일 악성 코드 추정	350억 원
2018년 6월	코인레일	이메일 악성 코드 추정	400억 원
2017년 12월	유빗(구 야피존)	핫웰렛해킹	172억 원

최근 정보보호 기술 동향

➢ AI 기반 보안 위협 증가

- AI 기술 악용으로 인한 피싱, 딥페이크 등 새로운 공격 방식이 등장하고 있으며, AI 모델의 신뢰성 및 안전성 확보를 위한 AI TRiSM (AI Trust, Risk, and Security Management) 중요성 확대

➢ 공급망 보안

- 오픈소스 소프트웨어, 소프트웨어 개발 과정에서 발생할 수 있는 취약점을 이용한 공격이 증가하며, 공급망 전체의 보안 강화가 필수적

➢ 클라우드 보안

- 클라우드 환경에서의 데이터 유출 및 보안 사고 발생 위험이 높아짐에 따라 클라우드 보안 기술과 관리가 중요

➢ 제로 트러스트 아키텍처

- 모든 접근 시도를 의심하고 검증하는 제로 트러스트 모델이 사이버 위협에 효과적으로 대응할 수 있는 방안으로 주목받고 있음

최근 정보보호 기술 동향

➢ AI 기반 탐지 및 대응 기술

- AI 기술을 활용하여 이상 징후를 탐지하고, 공격에 대한 자동화된 대응 체계를 구축하는 연구가 활발히 진행 중

➢ 딥페이크 탐지 기술

- 딥페이크 기술을 이용한 정보 조작 및 허위 정보 확산에 대응하기 위한 기술 개발이 중요

➢ 랜섬웨어 공격 다양화

- 랜섬웨어 공격이 이중갈취 전략 등으로 진화하며, 데이터 유출 및 시스템 마비를 넘어 추가적인 공격을 시도하고 있어 이에 대응할 수 있는 기술 개발 필요

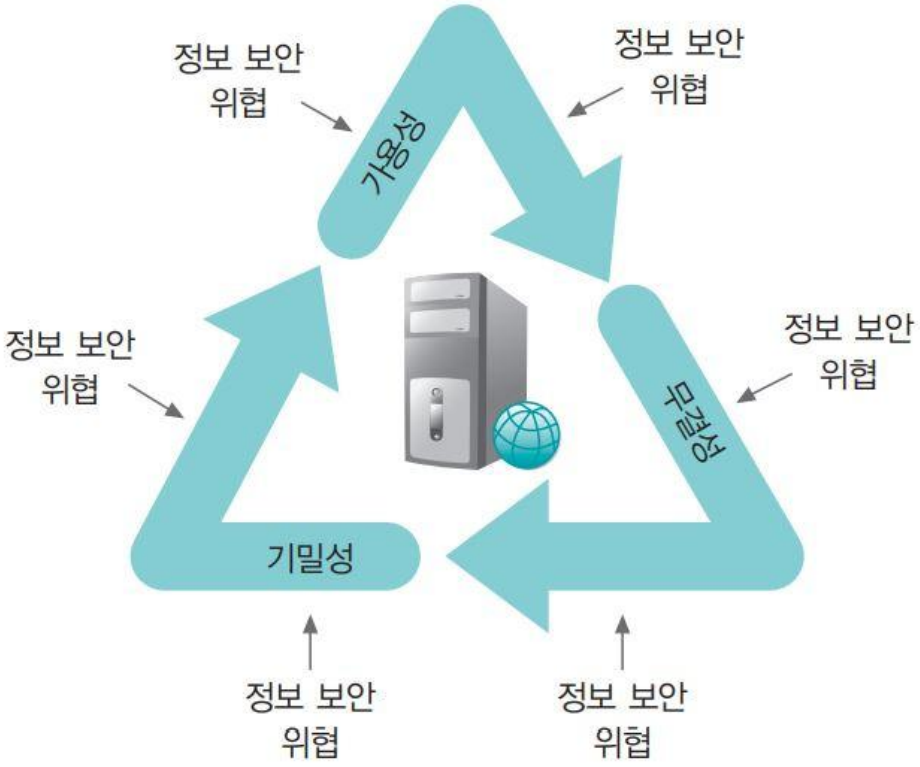
➢ OT/IoT 보안 위협

- 초연결 사회에서 OT(Operational Technology, 운영 기술) 및 IoT 기기에 대한 보안 위협이 증가하고 있으며, 이와 관련된 보안 기술 개발이 중요

2. 정보 보안의 이해

➢ 정보보호의 3대 요소

– 정보보호는 **기밀성, 무결성, 가용성**이라는 세 가지 목표를 가짐



[정보보호의 3요소]

2. 정보 보안의 이해

➢ 정보보호의 3대 요소

- **기밀성(Confidentiality)**
  - 인가된 사용자만 정보 자산에 접근할 수 있도록 하는 것으로, 일반적인 보안의 의미와 가장 가까움
  - 허가되지 않은 사람(비 인가자)이 정보에 접근하거나 노출되는 것을 방지
  - 보안과 관련 된 많은 시스템과 소프트웨어는 기밀성과 밀접한 관련이 있음
  - 방화벽, 암호, 패스워드 등은 기밀성을 보장하기 위한 대표적인 예

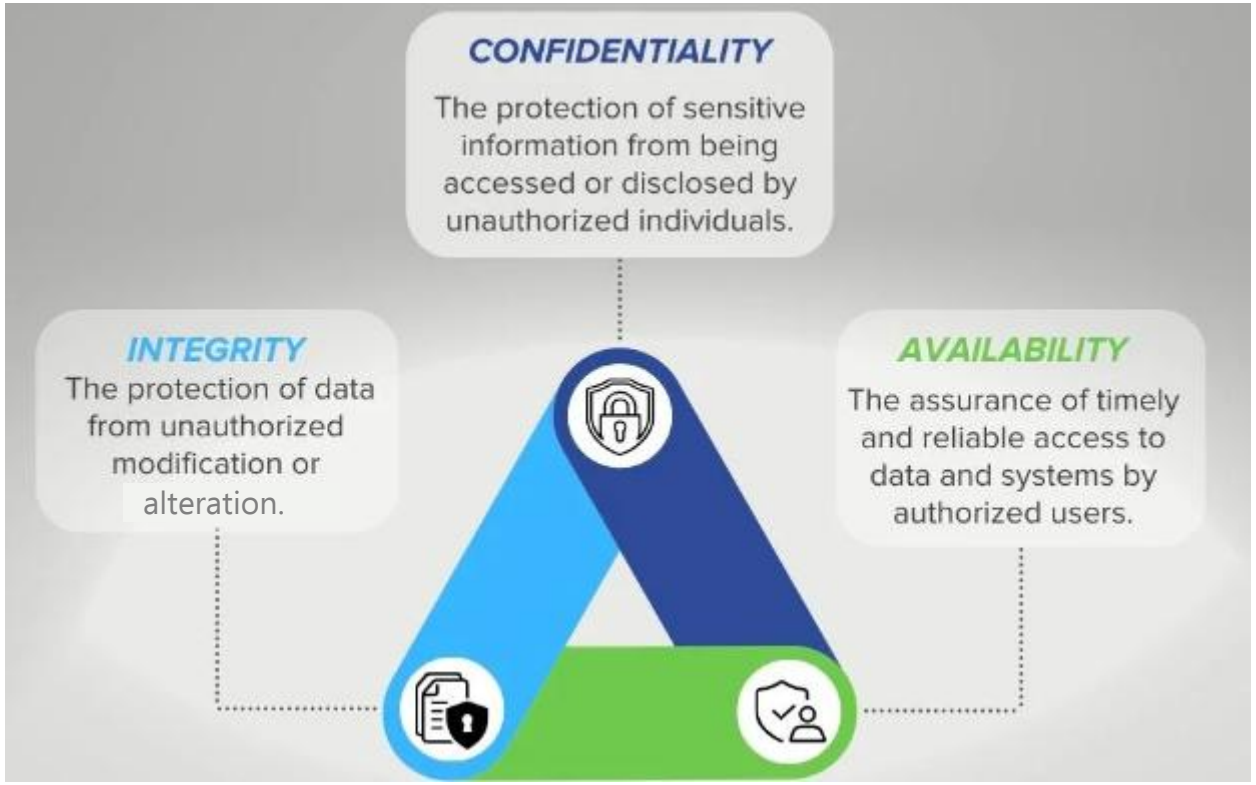
- **무결성(Integrity)**
  - 적절한 권한을 가진 사용자가 인가한 방법으로만 정보를 변경할 수 있도록 하는 것
  - 허가되지 않은 사람(비 인가자)에 의한 정보의 변경을 방지

- **가용성(Availability)**
  - 권한이 있는 사람들이 필요한 시점에 정보 자산에 대한 접근이 가능하도록 보장하는 것을 의미

2. 정보 보안의 이해

권한이 없는 사람의
접근이나 공개로 부터의 보호

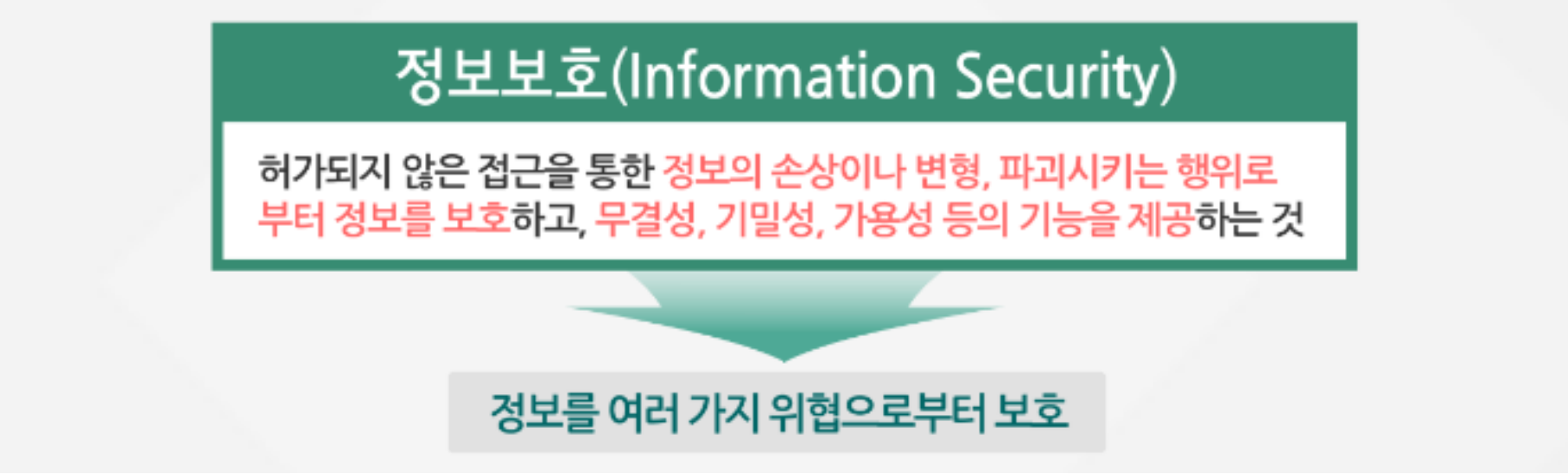
권한이 없는 사람에 의한
위/변조로 부터의 보호



권한이 있는 사람은
필요한 시점에 접근 가능

[CIA Triad]

2. 정보 보안의 이해



보안 대책을 수립하여 잠재적인 위협을 방지하거나
위협으로 인한 영향력을 최소화하는 것이 정보보호의 목표임

2. 정보 보안의 이해

➢ 보안 위협(Security Threat)

- 자연적 위협 요소
  - 홍수, 지진, 화재, 전력 차단 등 자연에 의한 위협
  - 사전에 예방할 수는 없지만 화재경보기, 온도계, 무정전 시스템 등을 설치하여 피해를 최소화할 수 있음

- 인간에 의한 위협 요소
  - 비 의도적 위협요소
    - 패스워드 공유, 데이터 백업 부재 등 인간의 실수와 태만으로 인한 정보 시스템 사고
  - 의도적(고의적) 위협 요소
    - 내부의 적, 컴퓨터 해킹, 위장(Masquerade)
    - 메시지 순서 변조 (Modification of Message Sequence)
    - 정보 변조 (Modification of Information)
    - 서비스 거부(Denial of Service), 부인(Repudiation)
    - 정보노출(Leakage of Information)
    - 신분 레이블 변조(Modification of Identification Label)

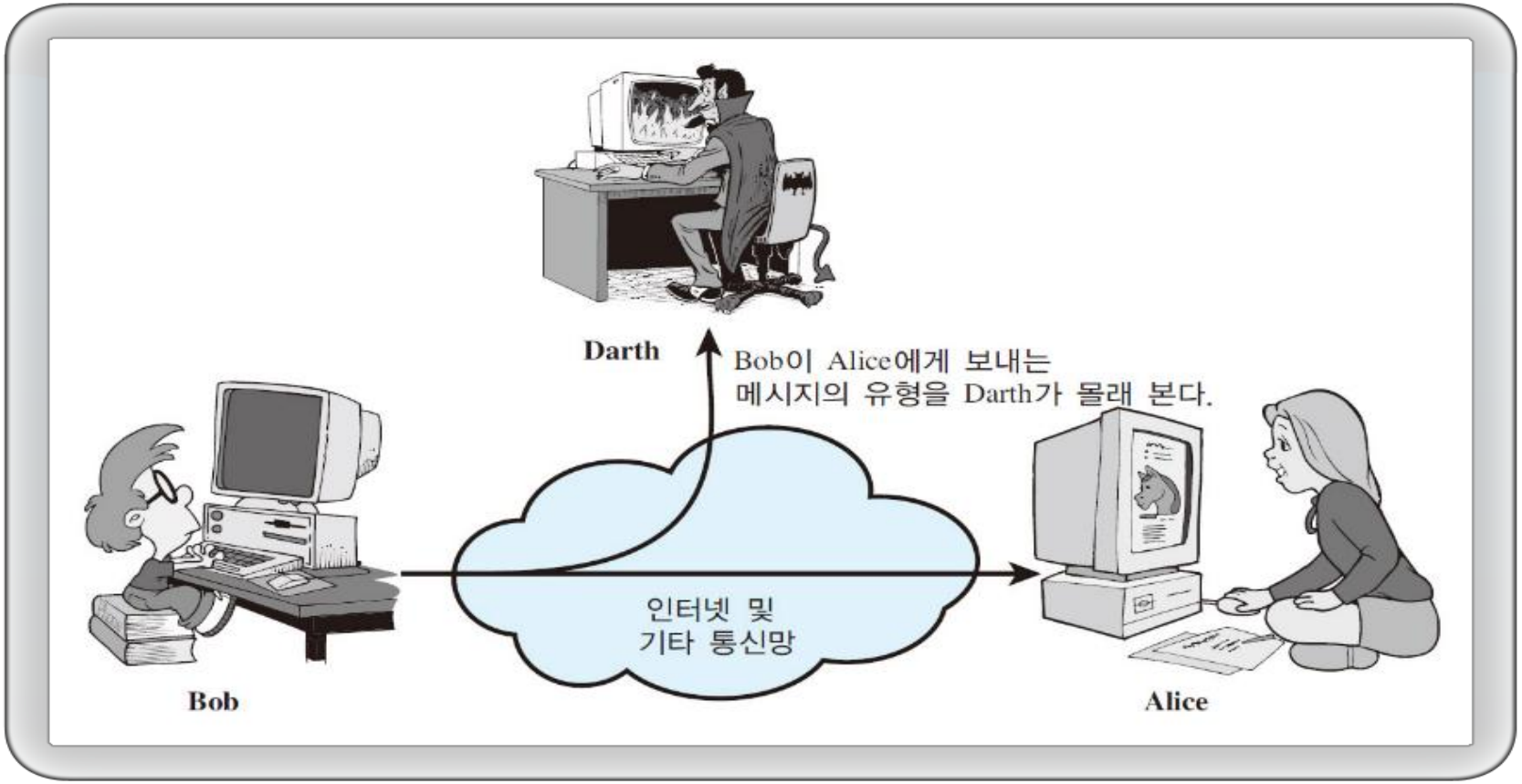
2. 정보 보안의 이해

➢ 보안 공격

- **소극적 공격(passive attack)**
  - 시스템으로부터 정보를 획득하거나 사용하려는 시도
  - 시스템 자원에는 영향을 끼치지 않는 공격 형태
  - 예) 도청

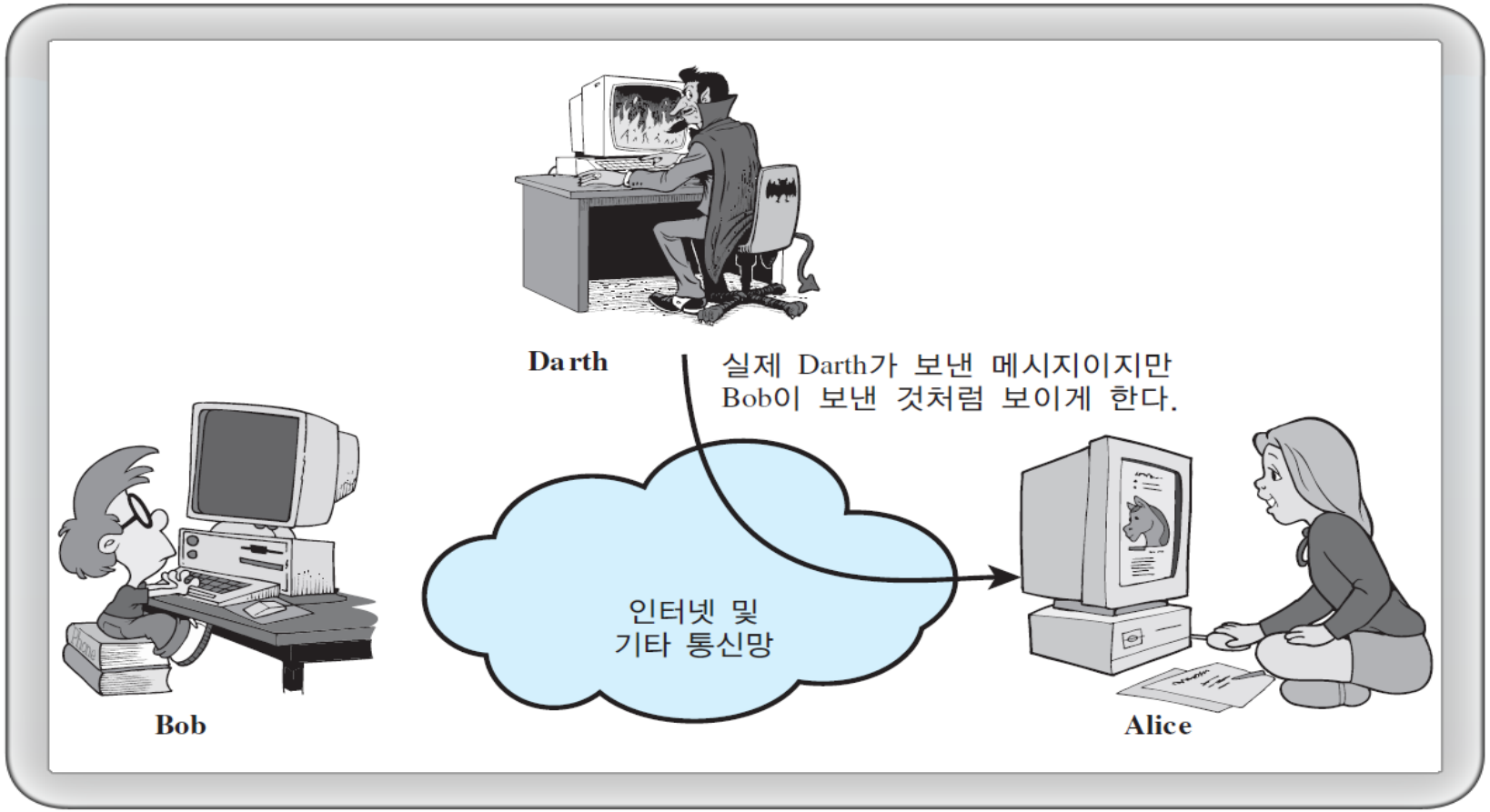
- **적극적 공격(active attack)**
  - 시스템 자원을 변경하거나 시스템 작동에 영향을 끼치는 공격 형태
  - 예) 위장, 재전송, 메시지 변조, 서비스 거부 등

2. 정보 보안의 이해



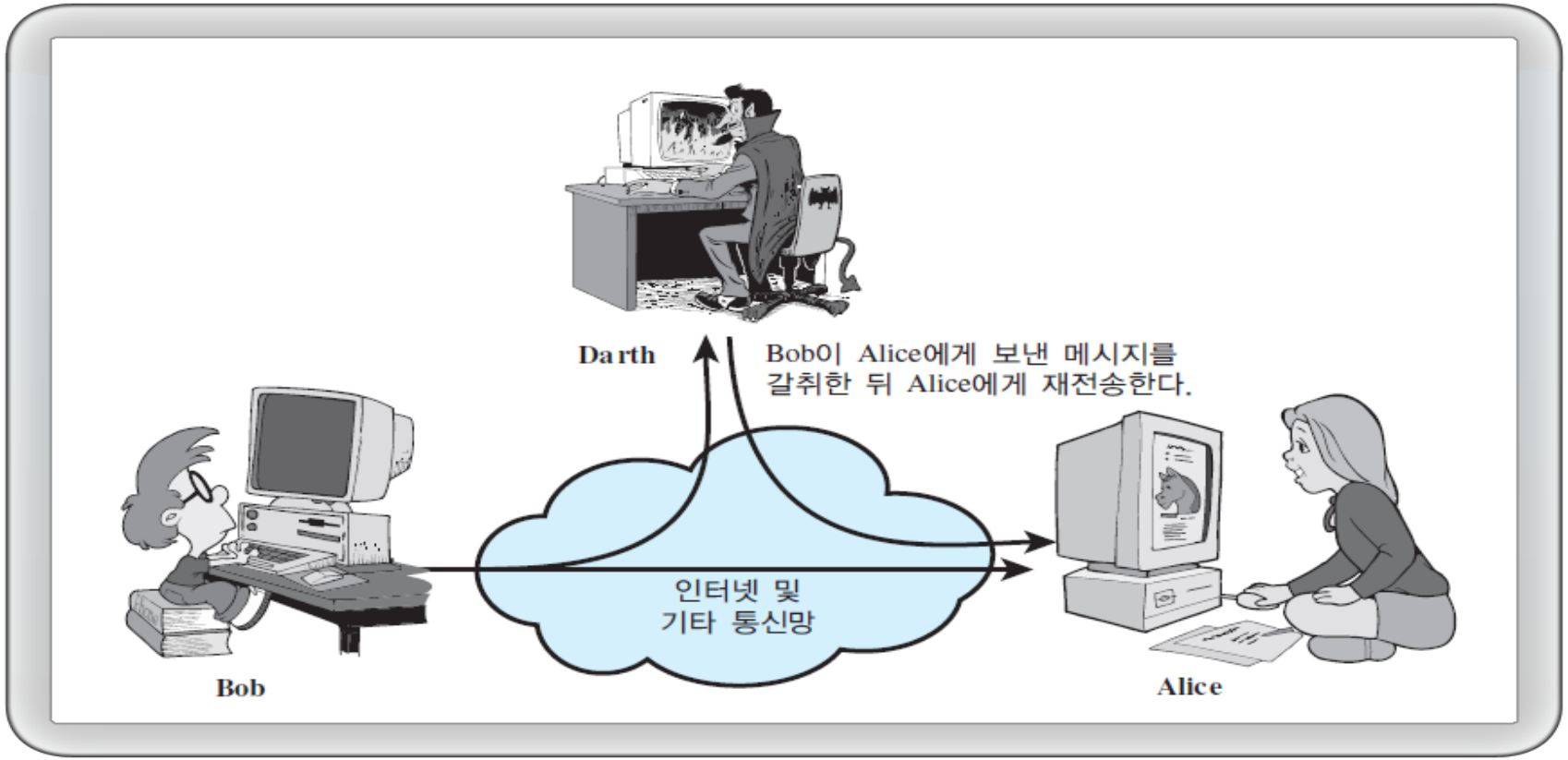
[소극적 공격 – 메시지 내용 도청(eavesdropping)]

2. 정보 보안의 이해



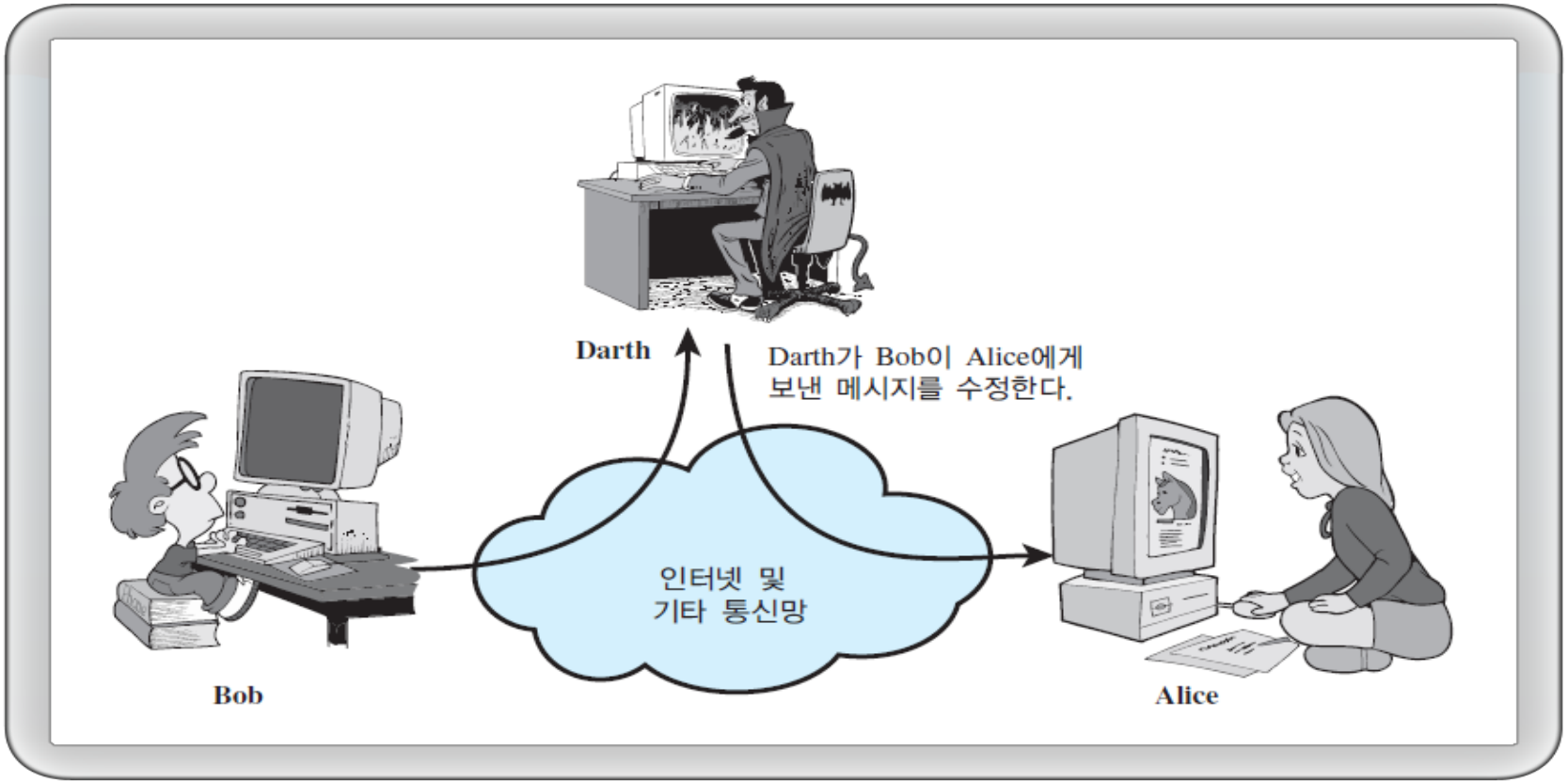
[적극적 공격 – 위장(masquerade)]

2. 정보 보안의 이해



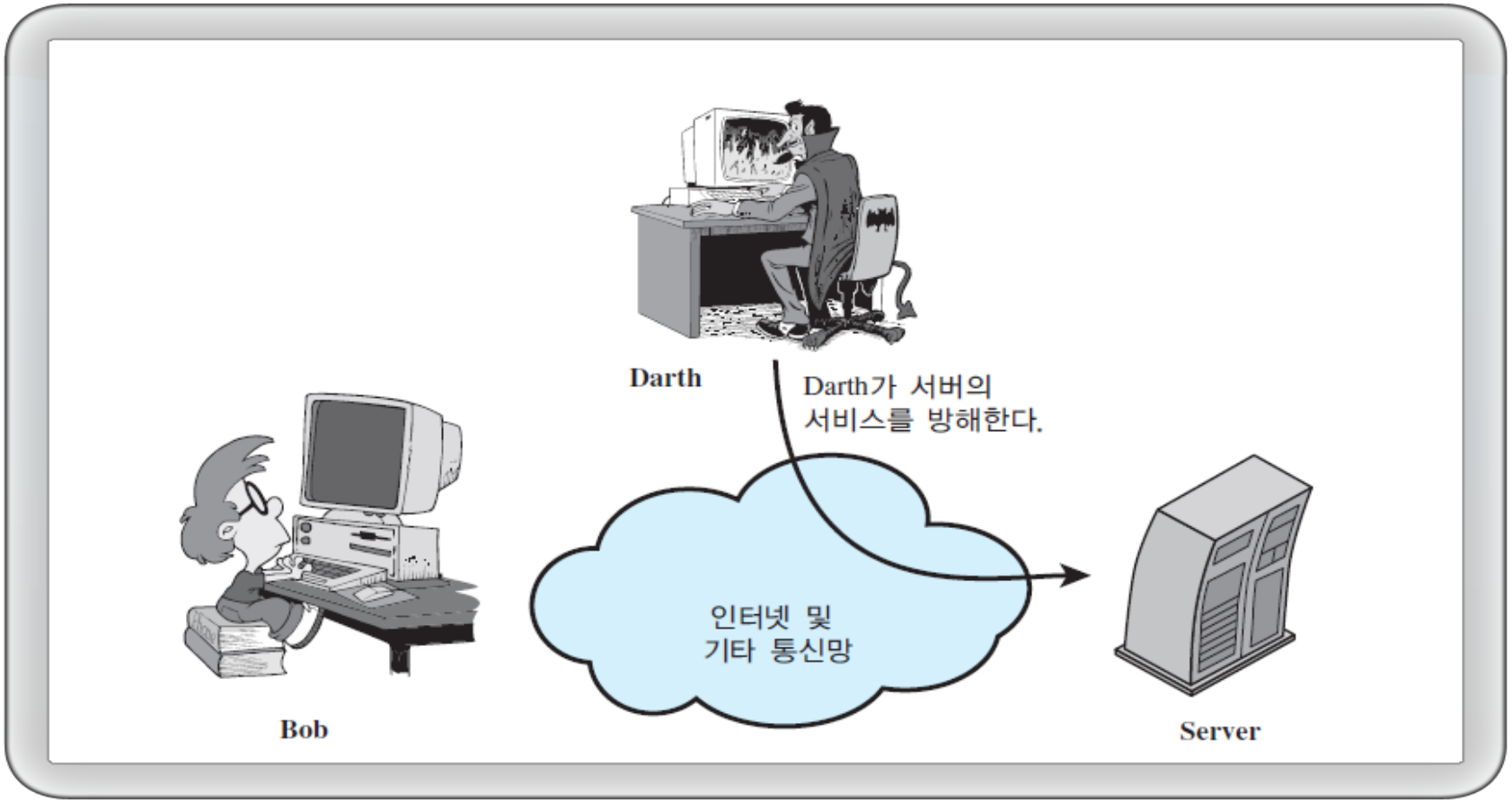
[적극적 공격 – 재전송(replay)]

2. 정보 보안의 이해



[적극적 공격 – 메시지 변조(modification)]

2. 정보 보안의 이해



[적극적 공격 – 서비스 거부(Denial of Service)]

참고 – 보안사고 사례1

美 AT&T, 1억명 넘는 고객 데이터 도난 당해

AI리포터 입력 2024.07.15 08:51

댓글 0 가

미국 최대 통신사 AT&T에서 사이버 공격으로 인해 1억 1000만명의 고객 데이터를 도난 당함
(해당 사고는 고객 데이터를 보관하는 클라우드 플랫폼에서 발생하였으며, 도난 당한 데이터에는 고객 전화 번호 외 2022년 5월 1일부터 2022년 10월 31일까지 통화 및 문자 메시지 기록이 포함)

참고 – 보안사고 사례2

포춘 50대 기업중 한 곳, 다크 엔젤스 랜섬웨어에 7천5백만 달러 지불...사상 최고액 피해

길민권 기자 | 승인 2024.07.31 17:02

다크 엔젤스, 2022년 5월에 활동 시작한 랜섬웨어 조직으로, 주로 대기업 타깃 공격

2024년 초 대기업 중 하나가 랜섬웨어 갱단에 7천5백만 달러를 지불한 사건 발생

참고 – 보안사고 사례3

뉴스데스크 전재홍

공항·방송사 올스톱..'MS 클라우드 장애' 전 세계 마비

입력 2024-07-19 19:47 | 수정 2024-07-19 19:58

PC의 보안 툴을 클라우드 기반으로 제공하는 크라우드스트라이크가 배포한 업데이트 패치 오류 발생으로 전 세계 각국의 공항, 은행, 방송국 등의 기능 마비

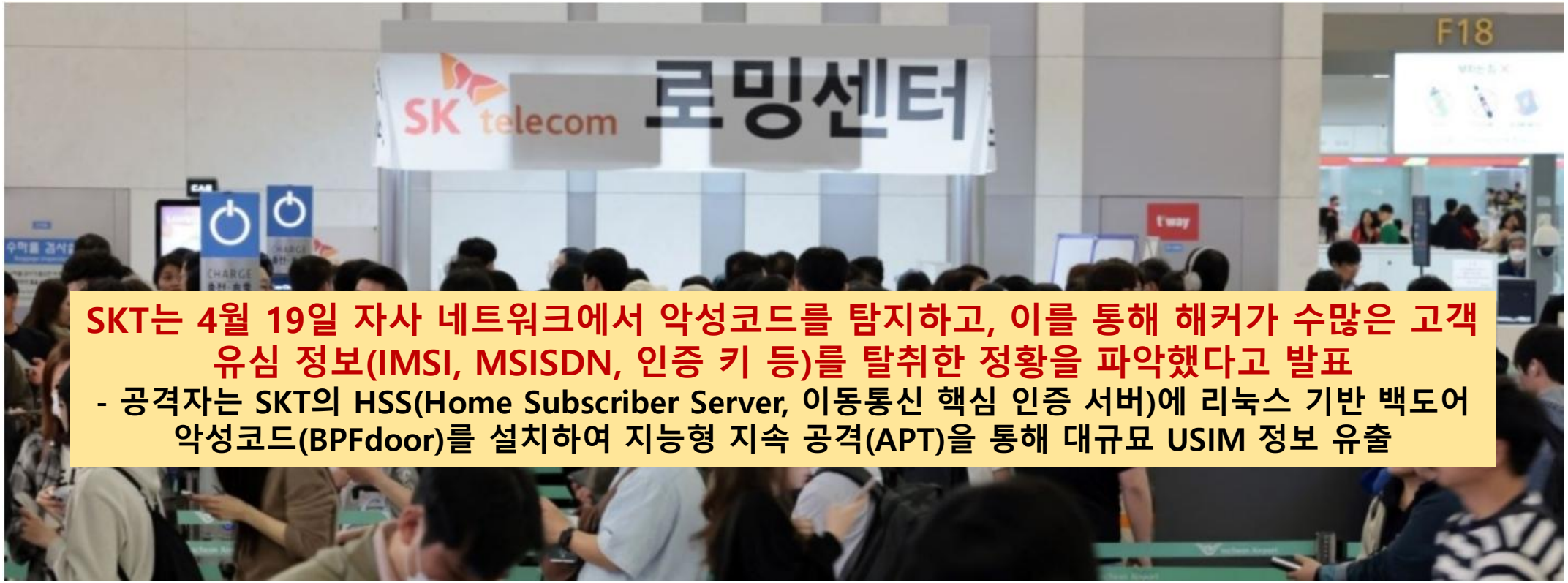
참고 – 보안사고 사례4

보안뉴스

#전체기사 | #시큐리티월드 | #사건사고 | #보안리포트

[SKT 해킹 사태 중간점검] 사건 경위와 현재 상황, 그리고 드러난 문제점

2025-05-01 13:35

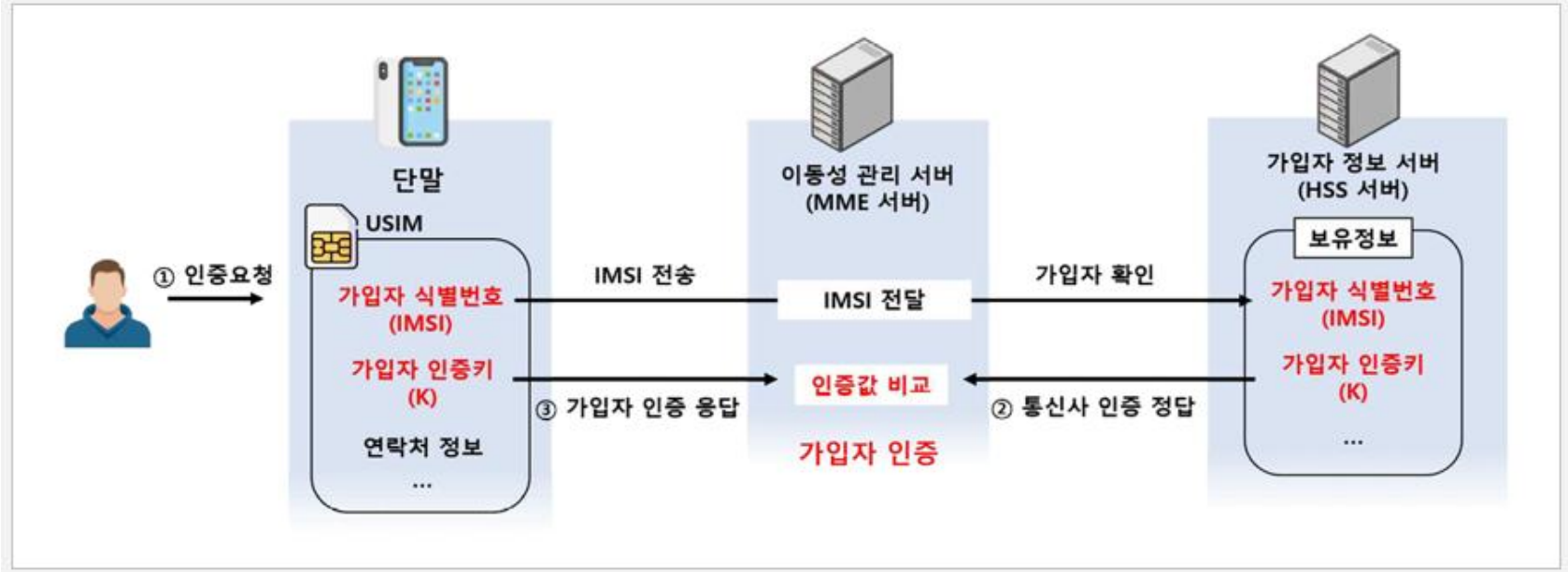


SKT는 4월 19일 자사 네트워크에서 악성코드를 탐지하고, 이를 통해 해커가 수많은 고객 유심 정보(IMSI, MSISDN, 인증 키 등)를 탈취한 정황을 파악했다고 발표

- 공격자는 SKT의 HSS(Home Subscriber Server, 이동통신 핵심 인증 서버)에 리눅스 기반 백도어 악성코드(BPFdoor)를 설치하여 지능형 지속 공격(APT)을 통해 대규모 USIM 정보 유출

참고 – 보안사고 사례4

➢ SKT 유심 해킹 사고



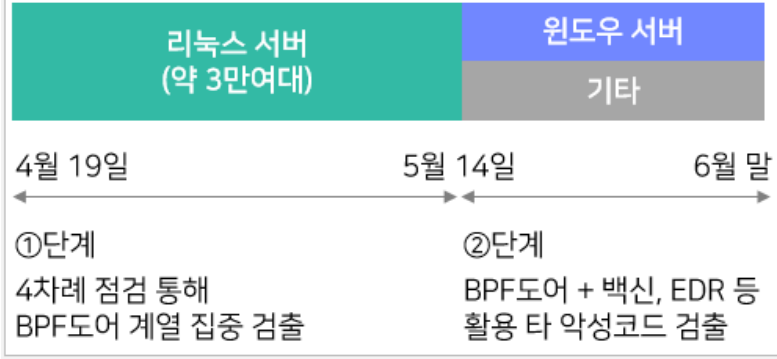
※사용자 인증에 필요한 정보

[유심 정보를 통한 가입자 인증 (출처: 개인정보보호위원회)]

- IMSI(International Mobile Subscriber Identity)와 가입자 인증키가 모두 유출되면 복제 유심을 만들어 인증을 시도할 가능성이 있음 → 단말기 고유식별번호(International Mobile Equipment Identity) 추가로 필요

참고 – 보안사고 사례4

- 1차 조사에서 공격 정황이 있는 3종, 5대 서버를 조사한 결과, 전화번호, IMSI 등 유심 복제에 활용될 수 있는 정보 4종과 유심 정보 처리 등에 필요한 SKT 관리용 정보 21종 유출 확인
  - IMEI가 유출되지 않은 것으로 확인되면서 유심을 복제해 다른 휴대전화에 꽂아 불법 행위를 하는 '심 스와핑' 공격 가능성은 낮은 것으로 판단(유심보호서비스로 방지가능)
- 2차 조사에서 감염된 서버는 5대에서 18대가 늘어난 총 23대이고, 악성코드도 25종 확인
  - 유출된 유심 정보의 규모는 IMSI 기준 2,695만 7,749건(SKT 이용자와 알뜰폰 이용자 수를 합친 2,500만 명을 웃도는 수치로, 스마트 워치 등 각종 단말기에 탑재된 유심 정보와 유효하지 않은 유심 정보까지 포함된 것으로 추정)
  - 정밀 분석을 통해 감염된 서버 중 IMEI 값을 포함한 개인정보를 저장한 2대의 서버에서 임시 저장된 파일에 총 29만 1,831건의 IMEI가 포함된 사실 확인



구분	1차 발표 (4.29.)	2차 발표 (5.19)	계
악성코드	4종	21종	25종
감염서버*	5대	18대	23대

* 정밀분석완료: 15대
* 정밀분석진행중: 8대

[그림 2] 조사단 2차 조사 결과 (출처: 과기정통부, 재구성: 이글루코퍼레이션)

참고 – 보안사고 사례4

➢ 사고 분석 결과

- 민관합동조사단은 포렌식 정밀분석을 통해 SK텔레콤의 서버 계정 정보 관리 부실과 과거 침해사고 대응 및 주요 정보 암호화 조치 미흡사항 확인

- 타 통신사 대비 정보보호 투자 미흡 등 기본적인 정보보호 활동의 문제점을 확인하여 재발 방지 조치를 진행

- 침해사고 신고 지연 및 과거 사고의 미신고, 자료 보전 명령 위반 등 정보통신망법상 준수 의무 위반 사항을 확인하여 과태료 등 행정 조치
  - 「정보통신망 이용촉진 및 정보보호 등에 관한 법률(이하 정보통신망법)」에 따라 정보통신서비스 제공자는 침해사고의 발생을 알게 된 때부터 24시간 이내에 그 사실을 과학기술정보통신부장관 또는 KISA에 신고해야 함

참고 – 보안사고 사례5

보안뉴스

#전체기사 | #시큐리티월드 | #사건사고 | #보안리포트

[예스24 해킹] 예스24, "15일까지 정상화 예상"...예매 관련 시스템 최우선 처리

2025-06-11 20:50

[보안뉴스 조재호 기자] 랜섬웨어 해킹으로 접속 장애 상태인 인터넷 서점 예스24가 15일까지 서비스를 정상화할 수 있을 것으로 예상했다.

공지사항

예스24 서비스 접속 오류 안내

예스24 서비스 접속 오류로 인해 불편함을 겪고 계신 모든 회원님들께 사과의 말씀을 드립니다.

현재 접속 오류는 랜섬웨어로 인한 장애로 인해 6월 9일 월요일 새벽 4시경부터 발생하였으며, 복구 작업 중에 있습니다.

다.

더불어 예스24는 장애로 인해 각종 불편함을 겪으신 전회원에 대해 구체적 보상안을 마련 중에 있습니다.
빠른 서비스 복구와 함께 전체 공지 및 개별 안내 드릴 수 있도록 하겠습니다.

다시 한 번 회원님들께 심려를 끼쳐드린 점 깊이 사과드립니다.

2025년 6월 9일 새벽 4시경, 예스24 홈페이지와 앱을 포함한 전 서비스가 랜섬웨어 공격으로 전면 마비(도서 주문, 공연 예매 등 모든 온라인 서비스 마비)

2. 정보 보안의 이해

[정보보호 대책]

물리적 조치	보안이 필요한 곳에 인가 받지 않은 자가 출입하는 것을 통제 예) 중요 시설 보호, 출입 통제, 도청 방지, 중요 자료의 백업 및 재난 복구 등
기술적 조치	정보 시스템, 서버, 네트워크 등에 대한 위험 요소와 취약점을 분석하고 필요한 보안 기술 적용 예) 시스템 접근 통제, 데이터 암호화 등
관리적 조치	정보에 대한 보호 및 관리를 위해 보안정책을 수립 예) 인원 관리, 정보시스템 사용에 대한 절차 관리, 사고 대책 관리 등

2. 정보 보안의 이해

[정보보호 대책]

- 중요 시설 보호, 출입 통제, 도청 방지
- 자료 백업 및 재난 복구 계획

물리적 대책

- 시스템 보호 : 인증 도구, 침입 탐지/차단 시스템, 보안 점검 도구 등
- 네트워크 보호 : 패킷 필터링, 방화벽 등
- 데이터 보호 : 암호화 등

기술적 대책

- 조직 : 보안 전담 조직 구성
- 규정 : 정책, 표준, 지침, 법, 제도
- 보안의식 : 교육, 홍보
- 기타 : 감시, 내부 감사

관리적 대책

2. 정보 보안의 이해

➢ 사이버 범죄의 유형

- 사이버 테러형 범죄는 해커 수준의 범죄, 일반 사이버 범죄는 인터넷을 이용한 일반인 수준의 범죄
- 정보 통신망 침해 범죄는 27%, 정보 통신망 이용 범죄는 73%, 불법 콘텐츠 범죄는 67%의 검거율
- 해킹이 점점 교묘해져서 추적하기가 어렵기 때문에 검거율이 점점 낮아지는 추세

표 1-2 사이버 범죄의 유형

구분	설명
사이버 테러형 범죄	정보 통신망 자체를 공격 대상으로 한다. 해킹, 바이러스 유포, 메일 폭탄, 서비스 거부(DoS) 공격 등 전자기적 침해 장비를 이용하여 컴퓨터 시스템과 정보 통신망을 공격하는 불법 행위다.
일반 사이버 범죄	사이버 공간을 이용한 일반적인 불법 행위로 사이버 도박, 사이버 스토킹, 사이버 성폭력, 사이버 명예훼손, 사이버 협박, 전자 상거래 사기, 개인 정보 유출 등의 행위를 가리킨다.

2. 정보 보안의 이해

➢ 정보보호 관련 법률

▪ 정보통신망 이용촉진 및 정보보호 등에 관한 법률

표 1-3 '정보통신망 이용촉진 및 정보보호 등에 관한 법률'의 주요 내용

조항	내용
제70조 제1항	사이버 명예 훼손(사실 유포) 시 3년 이하 징역 또는 3천만 원 이하 벌금
제70조 제2항	사이버 명예 훼손(허위 사실 유포) 시 7년 이하 징역, 10년 이하 자격 정지 또는 5천만 원 이하 벌금
제71조 제1항	다음 각 호의 하나에 해당하는 자는 5년 이하 징역 또는 5천만 원 이하 벌금 • 제1호: 이용자의 동의 없이 개인 정보를 수집한 자 • 제3호: 개인 정보를 목적 외에 이용한 자 및 제삼자에게 제공하거나 제공받은 자 • 제5호: 이용자의 개인 정보를 훼손·침해·누설한 자 • 제9호: 정보통신망에 침입한 자 • 제10호: 정보통신망에 장애가 발생하게 한 자 • 제11호: 타인의 정보를 훼손한 자 및 타인의 비밀을 침해·도용·누설한 자
제72조 제1항	다음 각 호의 하나에 해당하는 자는 3년 이하 징역 또는 3천만 원 이하 벌금 • 제2호: 속이는 행위에 의해 개인 정보를 수집한 자 • 제5호: 직무상 비밀을 누설한 자 및 목적 외에 사용한 자
제73조	다음 각 호의 하나에 해당하는 자는 2년 이하 징역 또는 2천만 원 이하 벌금 • 제1호: 기술적·관리적 조치 미이행으로 개인 정보를 분실·도난·유출·위조·변조·훼손한 정보통신 서비스 제공자 • 제2호: 청소년 유해 매체물임을 표시하지 않고 영리 목적으로 제공한 자 • 제3호: 청소년 유해 매체물 광고를 청소년에게 전송·공개한 자
제74조 제1항	다음 각 호의 하나에 해당하는 자는 1년 이하 징역 또는 1천만 원 이하 벌금 • 제1호: 표준화 및 인증을 위반한 제품을 표시·판매·진열한 자 • 제2호: 음란한 부호·문언·음향·영상 등을 배포·판매·임대·전시한 자 • 제3호: 공포와 불안을 유발하는 부호·문언·음향·화상·영상을 반복한 자 • 제4호: 사전 동의를 받지 않고 영리 목적의 광고성 정보를 전송한 자 • 제6호: 불법 행위를 위한 광고성 정보를 전송한 자

2. 정보 보안의 이해

➢ 정보보호 관련 법률

- **정보통신기반 보호법**
  - ISP(인터넷 서비스 사업자)나 통신사와 같은 주요 정보 통신 기반 시설에 대한 보호법
  - 주요 정보 통신 기반 시설을 교란·마비 또는 파괴한 자는 10년 이하의 징역 또는 1억 원 이하의 벌금에 처하는 것으로 규정

- **클라우드컴퓨팅법**
  - 일반화되고 있는 클라우드 환경과 관련한 서비스를 안전하게 이용할 수 있는 환경을 조성 하기 위한 법률
  - 이용자의 동의 없이 이용자 정보를 이용하거나 제3자에게 제공한 자 및 이용자의 동의 없음을 알면서도 영리 또는 부정한 목적으로 이용자 정보를 제공받은 자는 5년 이하의 징역 또는 5천만 원 이하의 벌금에 처함

- **전자정부법**
  - 많은 공공 데이터를 생성·관리하는 전자정부를 보호하기 위한 법
  - 행정 정보를 위조·변경·훼손하거나 말소하는 행위를 한 사람은 10년 이하의 징역에 처함
  - 행정 정보 공동 이용을 위한 정보 시스템을 정당한 이유 없이 위조·변경·훼손하거나 이용한 자, 행정 정보를 변경하거나 말소하는 방법 및 프로그램을 공개·유포하는 행위를 한 자는 5년 이하의 징역 또는 5천만 원 이하의 벌금에 처함

2. 정보 보안의 이해

➢ 보안 전문가의 자격 요건 : 윤리 의식

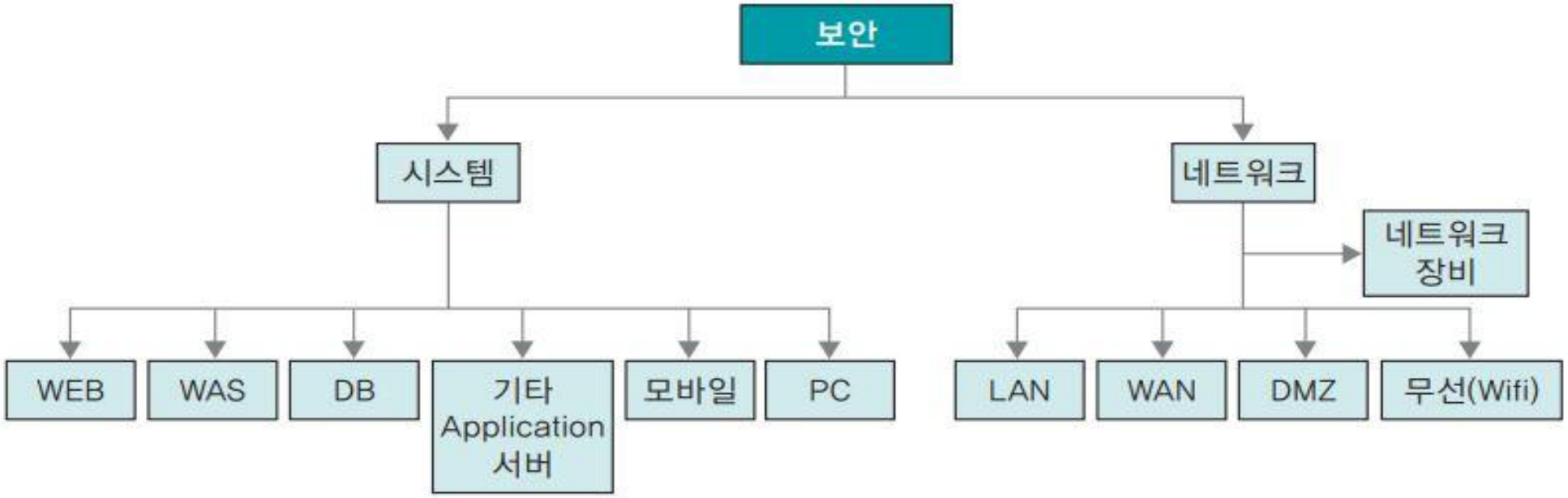
- 윤리 강령 : 보안이나 해킹과 관련된 기술을 배워 좋은 곳에 활용하는 전문가가 되기를 바라는 목적

정보통신 윤리 강령

- 우리는 타인의 자유와 권리를 존중한다.
- 우리는 바른 언어를 사용하고 예절을 지킨다.
- 우리는 건전하고 유익한 정보를 제공하고 올바르게 이용한다.
- 우리는 청소년 성장과 발전에 도움이 되도록 노력한다.
- 우리 모두는 따뜻한 디지털 세상을 만들기 위하여 서로 협력한다.

2. 정보 보안의 이해

➢ 보안 전문가의 자격 요건 : 다양한 분야의 지식



(a) 보안의 대상(객체)

2. 정보 보안의 이해

➢ 보안 전문가가 알아야 할 지식

보안 설정	Application 보안	관련 보안 시스템
네트워크 장비에 대한 보안 설정으로 네트워크 장비의 계정 관리, 접근 관리(ACL), VLAN 설정 등과 같이 장비 레벨에서 설정해야 할 보안 사항이 존재함	네크워크 장비에 대한 App 보안 사항은 telnet 등과 같이 관리 Daemon 등의 취약점과 관련한 일부 사항이 있음	네트워크의 경우 네트워크 장비 자체에서 설정할 수 있는 보안 수준에 제약이 많고, 목적 및 성능상 적합하지 않은 경우가 많아 별도의 보안 솔루션이 존재함 방화벽, 침입 탐지 시스템, 침입 차단 시스템, DLP, 스팸 차단 시스템 등과 같이 네트워크상에서 패킷을 분석하여 대응하는 형태의 솔루션들이 존재함
모든 시스템은 각자의 운영체제(OS)를 가지고 있으며, 각 OS별로 계정 관리, 권한 관리 등 흔히 시스템 보안이라고 말하는 사항들과 관련된 보안 설정이 필요함	시스템에 설치된 서비스의 종류에 따라 Application이 가지는 고유한 취약점들에 대한 보안이 필요함 WEB 서버의 경우 WEB 관련 취약점, DB 서버의 경우 DB 관련 취약점 등 설치된 application의 종류에 따라 보안 설정 및 관련 취약점이 존재함	시스템의 경우 대부분 시스템 자체의 보안 설정에 충실한 형태로 설계되어 있음 시스템 측면에서는 보안 사고 대응을 위한 보안 장비보다는 AD (Active Directory), SSO 등 운영과 관련한 권한 관리 시스템들을 주로 생각해볼 수 있음 PC 또는 모바일 환경의 경우 DRM, USB 통제 툴 등과 같이 사용자의 업무 환경과 관련한 보안 툴들이 존재함

흔히 AI 보안이라고 칭하는 영역은 패킷에서 특정한 패킷을 탐지하는 부분과 관련된 사항으로 AI 보안 이라는 이름 이전에도 전문가 시스템 등과 같이 비슷한 시도가 계속 되어 왔음

(b) 보안 사항

그림 1-14 보안 지식 체계

2. 정보 보안의 이해

➢ 보안 전문가가 알아야 할 다양한 분야의 지식

- **운영체제**
  - 운영체제 운영체제에는 윈도우, 유닉스, 리눅스, 맥 OS 등이 있음
    - 실무적으로 가장 중요한 운영체제는 가장 많이 사용되고 있는 윈도우
    - 금융권, 공공기관 등 중요 시스템에서는 유닉스를 많이 사용
    - 리눅스는 유닉스와 비슷한 환경을 제공하면서도 소스가 공개되어 있어 자유롭게 배우기 좋은 운영체제임

- **네트워크**
  - 네트워크는 하나의 시스템에서 데이터를 처리한 뒤 다른 시스템으로 전달하는 일종의 '길' 과 같은 역할 수행하며, 보안 전문가에게 있어 네트워크에 대한 이해는 필수적으로 요구됨
  - 1973년에 만들어진 TCP/IP는 지금도 네트워크의 기본이 되는 프로토콜로서 매우 중요

- **프로그래밍**
  - 기본적인 C 프로그래밍과 객체 지향 프로그래밍 및 웹 프로그래밍 대한 이해가 필요
  - 보안 시스템 개발자 및 응용 프로그램의 취약점 분석 등을 위해 프로그래밍 능력 필요

2. 정보 보안의 이해

- 서버
  - 보안 전문가는 기업이 안전하고 신뢰할 수 있는 서비스를 제공하도록 서버를 운용하기 위해 서버에 대한 이해가 필요
  - 서버 프로그램의 설치, 기본설정, 각 서버 별 인증 및 접근제어 및 데이터베이스의 경우 기본적인 SQL(Structured Query Language) 지식 필요

- 보안 시스템
  - 방화벽, 침입탐지시스템, 침입방지시스템, 네트워크 접근제어 시스템(NAC), 백신 등 보안 솔루션에 대한 시스템 별 기본 보안 통제와 적용 원리, 네트워크 상의 구성과 목적 등을 이해해야 함

- 모니터링 시스템
  - 네트워크 관리 시스템(NMS), 네트워크 트래픽 모니터링 시스템(MRTG)과 같은 모니터링 시스 템의 기본 개념 필요

2. 정보 보안의 이해

- **암호학**
  - 기밀성, 무결성, 인증 등 보안 서비스를 제공하기 위해 필요한 요소기술에 대한 이해
  - 암호와 해시의 차이, 대칭키 암호 알고리즘 및 비대칭 키 암호 알고리즘의 종류와 강도, 메시지 인증/사용자 인증, 키 분배 및 공개키 기반 구조 등에 대한 지식

- **정책과 절차**
  - 보안 전문가는 기술적인 부분 뿐만 아니라 보안 정책과 해당 기업의 핵심적인 업무 프로세스를 잘 이해하고 있어야 함
    - 이는 최고보안책임자(CSO, Chief Security Officer)가 되기 위한 요건임
  - 보안 정책에서 가장 핵심적인 요소는 보안 거버넌스임
    - 보안 거버넌스란 '조직의 보안을 달성하기 위한 구성원 간의 지배 구조'를 의미함

2. 정보 보안의 이해

➢ 정보보호 산업

- 정의 : 정보보호를 위한 기술 및 정보보호기술이 적용된 제품을 개발·생산 또는 유통하거나 이에 관련한 서비스를 제공하는 산업(정보보호산업법 제2조, 2015)

	정보보안	물리보안	융합보안
정의	컴퓨터 또는 네트워크상 정보 유출, 훼손 등을 방지하는 기술	재난, 재해, 범죄 등을 방지하는 기술	정보보안+물리보안 또는 정보보안+타 산업 보안 기술
세부 분야	• 네트워크보안/시스템보안 • 정보유출방지 시스템 • 암호/인증 시스템 • 보안관리 시스템 • 보안 컨설팅 • 보안시스템 유지관리/보안성 지속 서비스 • 보안관제 서비스 • 보안교육 및 훈련 서비스 • 공인/사설 인증서	• 보안장비용 카메라 • 보안장비용 저장장치 • CCTV 카메라 • 물리보안 시스템 개발 • 보안용 통신장비 제조 • 접근통제 장비 • 생체인식 보안시스템 • 경보/감시 장비 등	• 자동차 보안 • 항공 보안 • 의료 보안 • 스마트시티 보안 • 스마트 팩토리 보안 • 스마트 팜 보안 • 국방 보안 • 보안 로봇 등

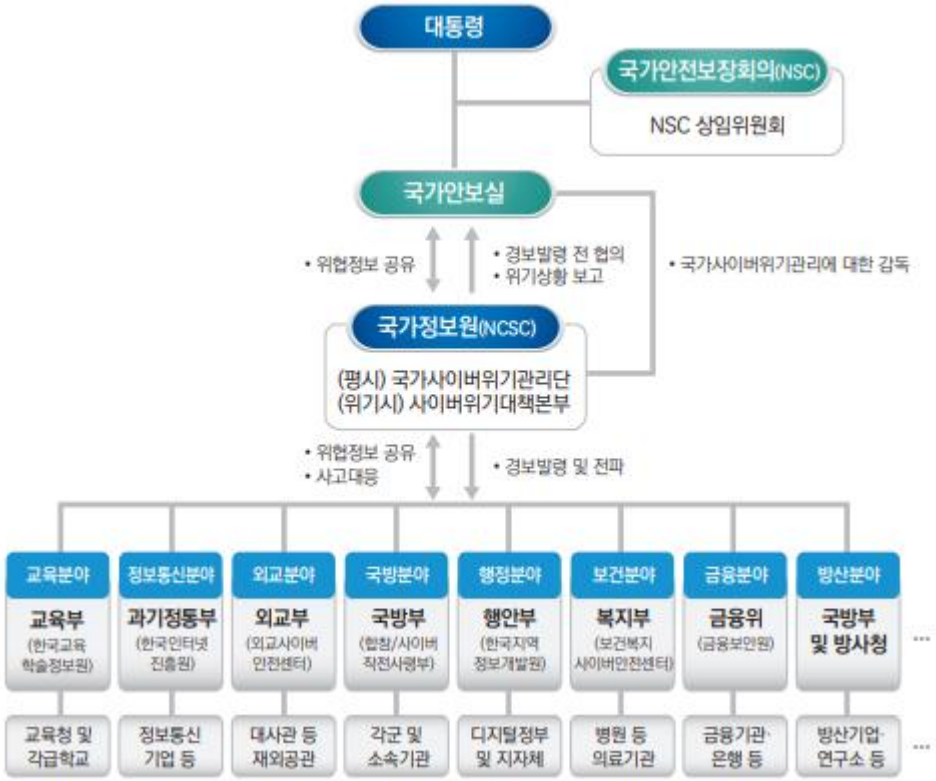
2. 정보 보안의 이해

[정보보안 기술의 분류]

공통기반 보안	시스템・디바이스 보안	네트워크 보안
암호, PKI, 멀티팩터 인증, 보안 취약점 분석 및 SW 보안 등	모바일・IoT 디바이스 보안, 시스템보안, 악성코드 분석 등	유선 네트워크 보안, 무선 네트워크 보안, 보안분석 및 관제 등
정보보안		
응용 서비스 보안	휴먼・바이오 인식, 대용량 검색 시스템, CCTV・무인전자 감시, 무자각・비제약 인식, 크라우드소싱 분석 등	스마트홈・시티 보안, 산업제어시스템 보안, 지능형 차량 보안, 헬스케어 보안, 항공・조선해양・국방 보안 등
클라우드 보안, 웹・이메일 보안, 데이터 보안, 금융・핀테크 보안, 디지털 포렌식 등		
정보보안	물리보안	융합보안

3. 정보보호 관련 기관 및 단체

구분	기관명	비고
국가기관	국가안보실	
	국가정보원	www.nis.go.kr
	과학기술정보통신부	www.msit.go.kr
	행정안전부	www.mois.go.kr
	금융위원회	www.fsc.go.kr
	개인정보보호위원회	www.pipcgo.kr
	외교부	www.mofa.go.kr
전문기관	한국인터넷진흥원	www.kisa.or.kr
	국가보안기술연구소	
	금융보안원	www.fsec.or.kr
	한국지역정보개발원	www.klid.or.kr
	한국전자통신연구소	www.etri.re.kr



[국가 사이버안보 수행체계 현황(2025)]

정보보호 기관 및 단체 - 국가기관

➢ 국가안보실

- 국가안전보장에 관한 대통령의 직무를 보좌하는 기관
- 사이버 안보를 확보하기 위해 관련 법·제도 개선, 인력양성 추진 등 **사이버안보 분야의 주요 정책 수립·조정**
- 2019년 4월 3일 사이버안보에 대한 중·장기 정책방향을 제시하는 **'국가 사이버안보전략'** 발표
- 2021년 12월에는 사이버정보비서관과 안보전략비서관을 통합하여 사이버안보 비서관을 신설하였고, 전통적 안보 개념을 뛰어넘는 사이버공간의 안보를 확보하기 위한 노력 강화
- 2024년 2월 1일 '사이버공간 에서 자유·인권·법치의 가치를 수호하면서 국제적 역할과 책임을 다하는 글로벌 중추국가'로 비전을 설정한 새로운 '국가사이버안보전략' 발표

정보보호 기관 및 단체 - 국가기관

➢ 국가정보원(National Intelligence Service)

- 국가안전보장에 관련된 정보 및 보안 사무를 담당하기 위하여 대통령 직속으로 설치
- 「국가정보원법」과 「사이버안보 업무규정」 등 개별 법령에 따라 **국가 전체 영역을 포괄하는 사이버안보** 관련 정보 업무와 **공공부문을 대상으로 하는 사이버공격·위협의 예방·대응**업무 수행

① 국가정보기관으로서 수행하는 사이버안보정보 업무

- 국제 및 국가배후 해킹조직 등 사이버안보 관련 정보의 수집·작성·배포 직무를 수행하며, 직무 수행을 위하여 필요한 경우 현장조사·문서열람·시료채취·자료제출 요구 및 진술요청 등의 방식으로 조사 수행
- 외국의 정보·보안 기관 및 단체 기관과 정보협력체계를 구축하고, 관련 정보를 중앙행정기관 등에 배포·공유하기 위하여 **정보공유시스템을 구축·운영**
- 2016년부터 **'국가사이버위협 정보공유시스템(NCTI, National Cyber Threat Intelligence)'**을 구축·운영
- 2020년 10월부터 방산업체·국가핵심기술보유기업 등 국익 및 국가안보와 직결되는 민간 산업분야와 정보공유 협약을 체결하고 **인터넷 기반의 정보공유시스템(KCTI, Korea Cyber Threat Intelligence)**을 구축하여 정보서비스 진행
- 2023년 12월 기준 국가·공공기관 420개 및 방산업체를 비롯한 170개 민간기업이 정보공유시스템 이용 중

정보보호 기관 및 단체 - 국가기관

② 국가보안 기관으로서 수행하는 **공공부문 사이버 보안** 업무

- 국가정보원은 중앙행정기관 및 그 소속기관과 국가인권위원회, 고위공직자범죄수사처, 행정기관 소속 위원회, 지방자치단체와 그 소속기관, 「공공기관 운영법」에 따른 공공기관, 지방공사·공단, 한국은행 등 주요 특수법인, 국립·공립학교, 정부출연연구기관 대상 **사이버공격·위협에 대한 예방·대응 직무**를 수행
- 사이버안보 기본대책 수립·시행, 보안성 검토, 정보보호시스템 등 도입·운영 관련 검증 및 보안대책 수립, 보안관리컨설팅, 교육·훈련, 실태평가, 정부보안관제체계 구축 및 중앙행정기관 등 대상 보안관제와 경보 발령, 사이버공격으로 인한 사고 발생 시 공격 주체 규명, 원인 분석 및 피해내역 확인 등을 위한 조사 실시

③ 국가사이버안보센터

- 2003년 발생한 1.25 인터넷 대란을 계기로 사이버공격에 대한 종합적이고 체계적인 예방·대응을 위하여 2004년 2월 국가사이버안전센터(NCSC)를 설립
- 「국가정보원법」 개정 및 「사이버안보 업무규정」 제정에 따라 2021년 1월 1일자로 <u>국가사이버 안보센터(NCSC)</u>로 명칭 변경
- 2023년 5월17일 정부산하기관 및 민간기업 전문가들과 함께 국가사이버안보센터에 **국가사이버 위기 관리단**을 설치하였으며, 국가안보실과 긴밀한 협의하여 국가 사이버위기를 통합 관리

정보보호 기관 및 단체 - 국가기관

➢ 과학기술정보통신부

- 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」·「정보통신기반 보호법」·「국가정보화기본법」·「전자서명법」·「정보보호산업의 진흥에 관한 법률」 등 관계 법령에 근거
- 민간분야 침해사고 예방·대응체계의 구축·운영, 민간분야 주요정보통신 기반시설의 지정 권고 및 취약점 분석·평가, 전자인증, 정보보호산업 및 정보보호 인력 관련 주요 정책 수립·추진 등 **민간분야 정보보호에 관한 업무** 수행
  - 사이버보안 강화를 통한 국민 불안 해소를 국정과제로 하여 안전한 사이버환경을 조성하기 위한 정책 추진
  - **사이버위협 정보 분석·공유 시스템(C-TAS: Cyber Threat Analysis & Sharing)**을 개방형으로 전환(2022. 1.)하여 기업 누구나 활용할 수 있도록 지원하고 위협상황을 신속히 전파할 수 있는 체계 구축
  - 정보보호산업 생태계의 새로운 거점을 마련하기 위하여 2017년 9월 경기도 판교 제2테크노 밸리에 정보보호 클러스터 조성
  - 2023년에는 부산·울산·경남을 거점으로 하는 정보보호 클러스터 신설

정보보호 기관 및 단체 - 국가기관

➢ 행정안전부

- 「전자정부법」·「정보통신기반 보호법」 등 관계 법령에 따라 소관 정보보호 업무를 수행하고 있으며, **디지털 정부의 사이버침해 대응 역량을 강화하기 위하여 국가정보자원 관리원과 한국지역정보개발원 및 광역자치단체 17곳에 사이버침해대응센터를 구축**하여 각종 사이버공격에 공동 대응

➢ 금융위원회

- 「전자금융거래법」 등 관계 법령에 근거하여 **전자금융 거래 이용자 보호와 전자금융 분야의 정보보안정책 수립 및 제도개선** 업무 수행
- 2023년 금융위원회는 금융분야 내 첨단기술 도입, 다양한 지급결제 수단 등으로 디지털금융 혁신이 가속화됨에 따라 금융보안 및 정보보호 기능을 더욱 강화하기 위하여 금융안전 전담조직인 '금융안전과'(2023. 10.)를 설치

➢ 개인정보보호위원회

- 2020년 8월 5일 데이터 3법(「개인정보보호법」, 「정보통신망법」, 「신용정보법」) 시행에 따라 종전 행정안전부와 방송통신위원회 등에 흩어져 있던 개인정보보호 기능을 이관받아 중앙행정기관으로 출범
- **데이터 경제 시대에 부합하는 개인정보 관련 정책을 총괄·조정하며, 유관기관과 협력을 통하여 개인정보 침해·유출 사고 예방 및 대응**

정보보호 기관 및 단체 - 국가기관

➢ 외교부

- 정보통신기술의 급속한 발전과 디지털 전환 가속화 등 사이버환경의 변화와 함께 사이버 위협은 국제 평화안보와 국가안보에 중대한 도전으로 부상
- 사이버공간의 특성인 개방성과 초국경성으로 인하여 사이버위협은 시간적·장소적 제약없이 여러 국가에 피해를 일으키므로 사이버안보는 개별 국가의 노력을 넘어 국제 공조가 필수적
- 2019년부터 유엔총회 1위원회 산하 정보안보 개방형 워킹그룹(OEWG, Open-ended Working Group)에 참여하여 사이버 공간에서의 국가행동 규범, 국제법 적용 원칙, 역량 강화 및 신뢰구축 증진

정보보호 기관 및 단체 - 전문기관

➢ 한국인터넷진흥원(KISA, Korea Internet and Security Agency)

- 「정보통신망 이용 촉진 및 정보보호 등에 관한 법률」 제52조에 의거하여 정보통신망의 고도화 및 안전한 이용 촉진, 정보통신망의 이용에 따른 역기능 분석 및 대책연구, 인터넷주소자원 관리 등을 목적으로 설립된 인터넷 및 정보보호 진흥기관
- 민간분야 사이버 침해사고 예방 및 대응, 개인정보보호 및 피해 대응, 정보보호산업 및 인력양성, 정보보호 대국민서비스, 국가도메인(.kr/.한국) 서비스, 불법스팸 관련 고충처리, 블록체인과 같은 ICT 신산업 진흥 등의 업무 수행

- 사이버침해 사고 대응을 위하여 인터넷침해대응센터(KISC, Korea Internet Security Center)를 운영하여 인터넷 트래픽의 이상징후를 365일 24시간 상시 모니터링하고 주요 취약점에 대한 보안권고문 배포
- 국가를 대표하는 인터넷침해사고 대응팀(CERTCC)으로서 국내외 관계기관과 글로벌 공조체계를 구축하고 사이버위협에 선제적으로 대응
- 사이버보안빅데이터센터 및 민·관 협력 플랫폼인 'K-사이버보안 대연합'을 운영하여 사이버위협 정보를 민간과 신속하게 공유
- 중소·영세 사업자를 위해서는 맞춤형 전용백신 및 웹 취약점 점검 도구 등을 무료로 배포
- 사이버대피소를 구축·운영하여 DDoS 공격으로부터 서비스를 안정적으로 제공할 수 있도록 지원

정보보호 기관 및 단체 - 전문기관

➢ 국가보안기술연구소(NSR, National Security Research Institute)

- 「과학기술 분야 정부출연연구기관 등의 설립·운영 및 육성에 관한 법률」에 근거하여2000년에 설립된 정보보호 **전문연구기관**
- **공공 분야의 사이버 안전을 위한 연구·개발을 수행**하고 있으며, 국가 암호기술 연구, 해킹 대응 등 각종 정보 보안 기술 개발, 관련 기반 구축 및 지원
  - 무인 이동체 위협분석, 클라우드 신뢰성 강화 등 기술발전에 대응하여 보안 기술 연구·개발의 범위를 지속적으로 확대
  - 국가 사이버안보를 위한 정책연구를 수행하여 관계기관에 제공하고, 국외 유관 정부부처, 연구기관 등과의 협력을 통하여 국제 사회 교류 주도

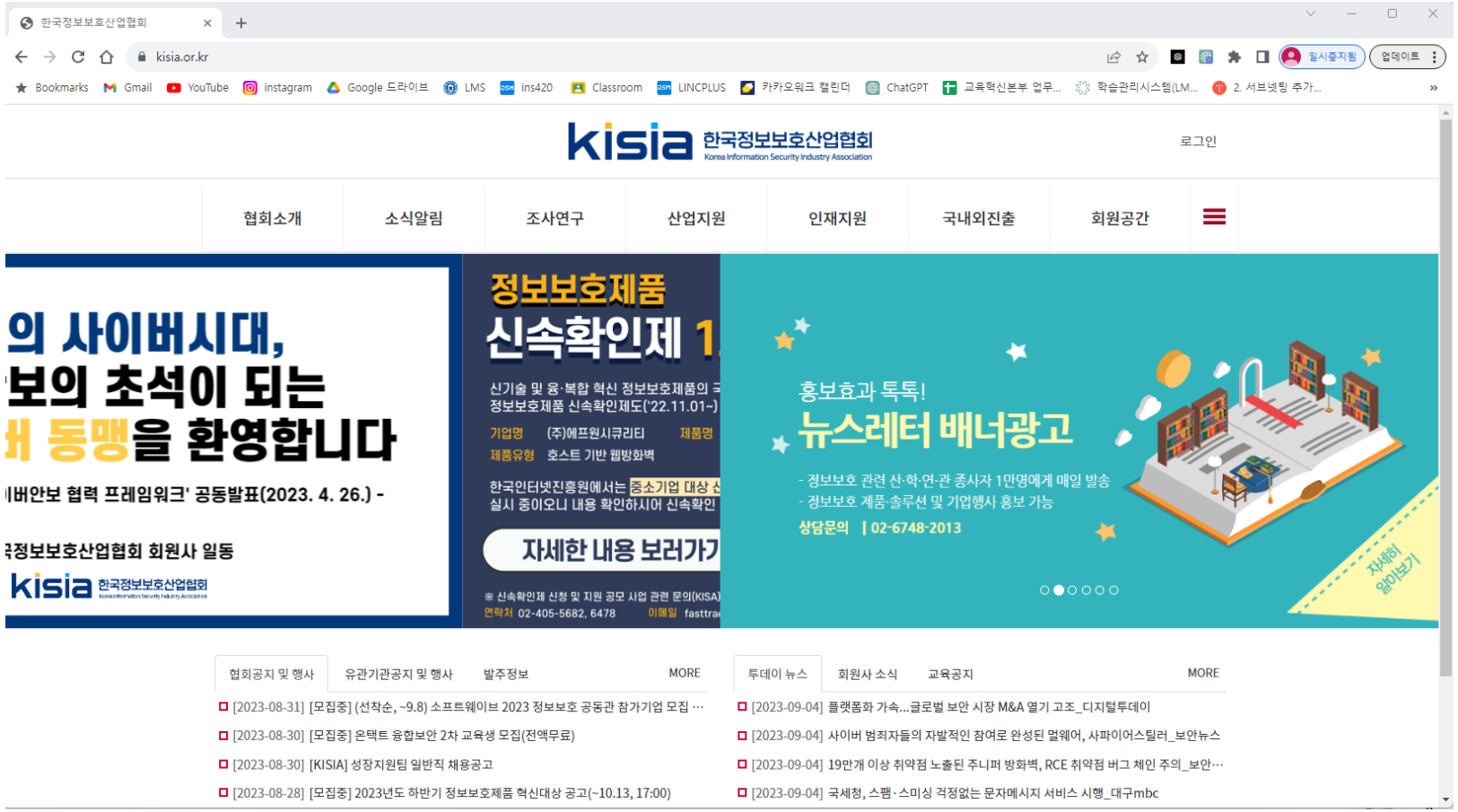
- 국가 사이버안보 강화를 위한 인재양성의 중요성을 인식하고 국가차원의 사이버위기 대응능력 향상을 목적으로 2014년부터 **사이버안전 훈련센터(CSTEC, Cyber Security Training and Exercise Center)** 운영
- 국가보안기술연구소가 축적한 시험평가 및 취약성 분석기술을 기반으로 안전성과 신뢰성이 검증된 정보보호제품을 보급하기 위하여 IT보안인증사무국에서 정보보호제품 인증업무 수행

정보보호 기관 및 단체 - 전문기관

- 금융보안원(FSI, Financial Security Institute)
  - 금융보안연구원과 금융결제원·코스콤의 금융정보공유·분석센터(ISAC, Information Sharing and Analysis Center) 기능을 통합하여 2015년 4월 출범
  - 금융 분야 정보통신기반시설의 취약점 및 침해요인에 관한 정보를 공유·전파하고, 침해사고 실시간 경보·분석 체계 운영, 주요정보통신기반시설에 대한 취약점 분석·평가, 보호 대책 수립 지원 수행
  - 「전자금융감독규정」에 따른 침해사고대응기관으로, 침해사고 정보공유체계 구축·운영, 침해사고의 예보·경보 발령, 금융권 통합보안관제센터 운영, 침해사고 조사·분석, 고위험군 악성코드 수집·분석, 디도스 공격 비상대응센터 구축·운영, 침해사고 비상 대응훈련 실시 등 침해사고 대응 업무 수행

참고

➢ 한국정보보호산업협회



4. 정보보호 자격증 제도

[정보보호 전문 자격증 현황]

구분	명칭	분류	주관기관
국내	정보보안기사, 산업기사	기사·산업기사	과학기술정보통신부, 한국방송통신전파진흥원
	정보보호전문가(SIS)	1급, 2급 ※자격유지	한국인터넷진흥원
	개인정보관리사(CPPG)	-	한국CPO포럼
	개인정보취급사(CPPF)	-	한국CPO포럼
	디지털포렌식전문가	1급, 2급	한국포렌식학회, 한국인터넷진흥원
	산업보안관리사	-	산업통상자원부, 한국산업기술보호협회
	사이버포렌식전문가(CCFP)	-	사이버포렌식전문가협회
국외	정보시스템보안전문가(CISSP)	-	국제정보시스템보안자격컨소시엄(ISC2)
	정보보호관리자(CISM)	-	국제정보시스템감사통제협회(ISACA)

4. 정보보호 자격증 제도

➢ 정보보안기사·산업기사

- 2012년 신설, 필기시험과 실기시험으로 구성
  - 산업기사는 **시스템 보안, 네트워크 보안, 애플리케이션 보안, 정보보안 일반** 등 4개 과목
  - 정보보안기사는 **정보보안관리 및 법규** 과목을 추가한 5개 과목
- 필기시험은 객관식, 실기시험은 단답형·서술형·실무형 등 3가지 유형
- 2022년부터 한국방송통신전파진흥원에서 주관하며, 2023년 부터 CBT 검정

[정보보안 국가기술자격시험 응시자 및 합격자 현황]

연도	정보보안기사			정보보안산업기사		
	실기 응시자	합격자	최종 합격률	실기 응시자	합격자	최종 합격률
2013	3,187	210	6.6	436	149	34.2
2014	2,558	315	12.3	556	87	15.7
2015	3,853	488	12.7	670	252	37.6
2016	4,144	306	7.4	1,292	247	19.1
2017	5,122	631	12.3	1,456	500	34.3
2018	4,650	805	17.3	1,225	288	23.5
2019	4,336	461	10.6	982	254	25.9
2020	4,372	348	8.0	886	331	37.4
2021	3,956	76	2.0	923	294	31.8
2022	4,131	560	13.6	898	130	14.5
2023	4,561	446	9.78	720	96	13.3
2024	6,029	943	15.6	777	193	24.8
합계	50,899	5,589	11.0	10,821	2,821	26.1

4. 정보보호 자격증 제도

➢ 디지털포렌식 전문가

- 2016년부터 시행
- 1급 시험은 디스크 포렌식, 데이터베이스 포렌식, 네트워크 포렌식, 모바일 포렌식, 침해사고 대응 포렌식 등의 기법을 활용한 문제해결 능력 평가
- 2급 시험은 컴퓨터 구조와 디지털 저장매체, 파일시스템과 운영체제, 응용프로그램과 네트워크 이해, 데이터베이스, 디지털 포렌식 개론 5개 과목으로 구성된 필기시험과 디지털 포렌식 실무형 문제로 구성

➢ 산업보안관리사

- 2016년 산업통상자원부장관의 승인을 받아 2017년부터 국가공인 민간자격으로 시행
- 필기시험으로 운영하며, 관리적 보안, 물리적보안, 기술적보안, 보안사고대응, 보안지식경영 등 총 5개 과목으로 구성
- 국가공인 민간자격으로 승격된 이후 2017년부터 2023년까지 총 2,077명의 합격자 배출

4. 정보보호 자격증 제도

➢ 국내 정보보호 분야 민간자격으로 정부의 사이버인재양성 정책(2022. 7. 13.)에 대응하고, 정보보호 인력 양성 및 국민의 보안인식 수준 제고를 위해 개발

- 한국방송통신전파진흥원에서 2022~2023년 정보보호 분야 공인민간자격 발굴 및 운영에 관한 연구과제(한국정보보호학회 수행) 완료 후 2025년부터 시행할 예정
- 정보보호위험관리사(ISRM, Information Security Risk Manager) : 정보자산 보호, 관리체계 구축 운영, 위험관리 업무를 수행할 수 있는 능력 검정(실무전문가급)
- 정보보호능력검정(TOLIS, Test of Literacy in Information Security) : 정보보호 필요성, 보안사고 예방 등 기본소양과 정보보호에 대한 기본지식(능력검정용) 검정

구분	정보보호위험관리사	정보보호능력검정
응시 자격	4년제 대학 졸업(예정)자 및 동일 조건 ※ 전공 무관, 경력자의 경우 직무 분야 무관	제한 없음
필기	1. 정보보호 위험 관리 계획	1. 정보보호 개요
	2. 정보보호 위험 평가	2. 정보보호 기술
	3. 정보보호 위험 대응	3. 정보보호 동향
	4. 정보보호 관리체계 운영	4. 침해사고 예방 및 대응
	5. 정보보호 위험 대책 관리	5. 정보보호 윤리

4. 정보보호 자격증 제도

- CISSP(정보시스템보안전문가, Certified Information Systems Security Professional)
  - ISC2(International Information Systems Security Certification Consortium, Inc.)에서 주관하는 자격증
  - 보안 및 위기관리(Security and Risk Management), 보안 아키텍처 및 엔지니어링(Security Architecture and Engineering), 커뮤니케이션 및 네트워크 보안(Communication and Network Security) 등 8개 영역(domain) 평가
  - 시험 대상 8개 영역에서 5년 이상의 근무경력을 보유한 경우에만 응시 가능
    - 학사 이상의 학위 소지나 인정된 별도 전문 자격증 취득 등 특정 조건을 만족할 경우 4년 이하의 근무경력만으로도 취득 가능

[CISSP 자격 보유자 현황]

구분	전세계	한국	미국	일본	중국	홍콩	싱가포르	호주
보유자	156,054	2,144	95,243	3,699	4,136	1,968	2,963	3,305

4. 정보보호 자격증 제도

- CCFP(사이버포렌식 전문가, Certified Cyber Forensic Professional)
  - 법정에서 인정받을 수 있는 디지털 증거를 확보하기 위하여 포렌식 기법과 절차, 실행기준, 합법적· 윤리적 원칙에 관련한 전문성을 검정
  - 2003년부터 국내 자격으로 운영되었으나, 2013년 9월 ISC2(미국)로 CCFP 자격이 이관되면서 국제 공인 자격으로 승격
  - 그러나 2017년 ISC2 임원진과 인증서 정책 위원회의 합의에 따라 CCFP 자격 폐지를 알렸고, 해당 자격은 2020년 까지만 국제 공인 자격 등급이 유지
  - 2021년부터는 CCFP는 국내 민간자격으로 등록되어 운영하고 있으며, 사이버포렌식전문가 협회(KCFPA)가 소관하여 증거와 특징, 증거의 연계보관, 시행절차, 전문가 증언의 역할, 윤리강령의 과목을 필기 또는 실기의 방법으로 평가

4. 정보보호 자격증 제도

- CISM(정보보호관리자, Certified Information Security Manager)
  - 최소 5년의 정보보호 분야의 근무 경력이 요구되며, 이 중 3년 이상은 정보보호관리 업무 경험 필요
  - 평가영역은 정보보안 거버넌스, 정보 위험성 관리 및 준수, 정보 보안프로그램 개발 및 관리, 정보 보안 사고 관리 등 4개
  - 2023년 12월 기준, 전세계적으로 47,654명의 자격자가 배출되었고, 우리나라에서는 56명이 활동 중
  - CISM 자격시험은 한국정보시스템 감사통제협회(http://isaca.or.kr)가 주관

4. 정보보호 자격증 제도

➢ 국내외 정보보호 유관 자격증

▪ 정보시스템감리사

- 정보통신 감리 분야의 국가공인 자격증으로, 한국지능정보사회진흥원(NIA)에서 실시
- 기술사나 기사 취득 후 7년 이상의 실무 경력 또는 석사 취득 후 6년 이상의 실무 경력을 갖춘 고급기술자 대상
- 감리 및 사업관리, 소프트웨어공학, 데이터베이스, 시스템구조, 보안 등 5개 과목으로 구성

▪ CISA(정보시스템감사사, Certified Information System Auditor)

- IT/IS 감사· 통제·보증·정보보안 전문가를 위한 국제 공인 자격으로 1969년부터 ISACA(정보시스템감사통제협회, Information Systems Audit and Control Association)가 관리
- 정보시스템 감사 프로세스, IT 거버넌스 및 관리, 정보시스템 취득·개발 및 구현, 정보시스템 운영·유지보수 및 지원, 정보자산의 보호 등 5개 영역 출제
- 2023년 12월 기준, 현재 전세계적으로 90,767명이 자격을 취득하였고, 우리나라에서는 2,236명이 활동 중

5. 정보보안 직무

정보보안 전문가란?

정보보안전문가는 해커의 침입과 각종 바이러스 발생에 대비해
전산망을 전문적으로 보안 및 유지하고,
향후 일어날 수 있는 보안상 문제를 해결하고 예방합니다.

또한, 정보보안전문가가 되기 위해서는 운영체제, 데이터베이스, 시스템 관리, C언어,
네트워크 프로그래밍 등에 대한 선행 지식이 필요한데요.

이러한 정보보안전문가의 직무는 대표적으로
보안 솔루션, 모의해킹, 보안 관제, 악성코드 분석,디지털 포렌식, 보안 컨설팅이 있습니다.

5가지의 대표 직무는 어떤 것이 있는지,
또 직무별 필요한 지식은 어떤 것이 있는지 살펴봅시다!

출처:한국직업사전

5. 정보보안 직무

보안솔루션 엔지니어

보안솔루션 엔지니어는 단순하게 말해, 보안 솔루션을 다루는 일을 하는 기술자입니다.

예를들어 네트워크단에 들어가는 보안장비를 다룹니다.
대표적인 장비는 방화벽, IDS, IPS, 웹방화벽, VPN, DDoS 등등 있는데,
해당 장비에 대해서 설계, 구축, 기술지원, 유지보수,
장애 처리/복구 등 다양한 트러블슈팅 작업을 하는 직업입니다.

기업이나 개인의 자산 및 정보를 유출, 해킹하는 위협에서
보호할 수 있는 보안프로그램을 개발하며,

필요 지식으로는
C, JAVA, JSP, Database, WEB/WAS,Linux, Windows server가 있습니다.

출처:한국직업능력개발원

정보보안관제사

보안관제사란, 정보 시스템의 서버, 네트워크 장비 및 정보보안장비에 대한
전문지식과 운용기술을 갖추고, 이와 더불어 실시간 정보보안관제 기술과 능력,
보안정책수립과 보안대책 구현, 취약점 진단 및 침해사고 분석의 기술 등
다양한 보안전문 능력을 보유하고, 사이버공격에 대한
신속하고 정확한 대응 업무 수행 능력을 요하는 직무입니다.

필요 지식으로는 TCP/IP 이론, Linux, Windows server, 파일 구조, 패킷 분석,
WireShark, Forensic가 있습니다.

정보보안관제사 자격증은 1급,2급,3급과 필기, 실기시험으로 나뉘어져 있으며,
응시자격으로는 1급은 기사 자격증 취득 후 1년 이상의 실무 종사자만 응시할 수 있고
2급은 전문대학 학생 이상, 3급은 응시자격 제한이 없습니다.

출처:한국직업능력개발원

5. 정보보안 직무

악성코드분석가

악성코드분석가는 악성코드에 대한 분석을 하여서
컴퓨터에 대한 피해를 예방하기 위해 백신을 개발하고,
컴퓨터 파일 속에 어떤 파일들이 악성코드이고, 정상인지를 분석하는 직무입니다.
계속해서 변화하는 악성코드를 꾸준히 분석하는 아주 중요한 업무라고 할 수 있는데요.
뿐만아니라, 이미 많이 개발된 엔진에서 신규발생된 악성코드도 분석하며 개발합니다.

필요 지식으로는 C, C++, 어셈블리어, 시스템 분석,네트워크, 동적·정적 툴이 있습니다.

출처:한국직업능력개발원

디지털포렌식 전문가

우선 디지털 포렌식이란 뭘까요?
디지털 포렌식은 디지털적인 법과학의 한 분야로, 디지털 기기를 매개체로 하여
특정 행위의 사실관계를 법적으로 규명하고 증명하기 위한 절차와 방법입니다.

디지털 포렌식 전문가는 컴퓨터, 노트북, 휴대폰 등 디지털 기록 매체를 대상으로
범죄 수사의 단서가 되는 자료를 확보 및 복구하여 법적 증거자료로 만드는 일을 합니다.
원본 그대로의 데이터를 변조 없이 압수하는 것이 중요하며 과학적인 분석기술로 삭제되거나
암호화된 파일을 찾아내고 복구하는 것 또한 핵심 임무입니다.
과거에는 형사들이 범죄자들의 지문이나 족적 DNA 등을 확보하거나,
자백을 이끌어 내는데 중점을 뒀다면,
현재는 범인의 디지털 기기를 확보하는 것이 중요해졌습니다.

출처:한국직업능력개발원

5. 정보보안 직무

보안 컨설턴트

보안 컨설턴트는 말그대로 '컨설트' 고객의 의뢰를 받아
특정 문제에 관해 조언을 제시하거나 업무를 수행하는 직업입니다.
보안 컨설턴트의 주업무는 보안 관련된 컨설팅을 하는 일이며,
특정 기업이 보안관련하여 당면한 문제들을 분석하고 해결할 수 있도록
도와주는 직무라고 할 수 있습니다.

예를 들면, 여러 성공 또는 실패한 케이스를 분석하여, 특정 기업의 문제에 접목시킨 다음,
더 나은 방안을 제시하거나 해결할 수 있게 도와줍니다.
보안 컨설턴트의 목적은 리스크를 최소화시키기 위해 보안 위협의 요소들을 분석하고,
대응 방안을 제시하며, 최적의 정보보호 체계를 위한 방안을 세우는 것입니다.
더 크게 보자면 기업의 목적 자체를 달성하고, 경영상의 문제를 해결할 수도 있으며,
기업과 함께 변화를 실행하는 직무라고도 볼 수 있겠죠?

필요 지식으로는 Linux, Windows server, 개인정보보호법, 정보통신망법이 있습니다.

출처:한국직업사전

참고 – 국내 사이버위협 동향

➢ 과학기술정보통신부(한국인터넷진흥원)는「정보통신망 이용촉진 및 정보보호 등에 관한 법률」제48조의 3(침해사고 신고 등)에 따라 민간분야의 정보통신서비스 제공자로부터 침해사고 신고를 받음

표 1-1 | 유형별 침해사고 신고 현황

[단위 : 건수]

구 분 \ 연 도		2023년			2024년			2025년		
		上	下	종합	上	下	종합	上	下	종합
침해사고 신고	DDoS 공격	124(18.7%)	89(14.5%)	213(16.7%)	153(17.0%)	132(13.4%)	285(15.1%)	238(23.0%)	350(25.9%)	588(24.7%)
	악성코드	156(23.5%)	144(23.5%)	300(23.5%)	106(11.8%)	123(12.4%)	229(12.1%)	115(11.1%)	239(17.7%)	354(14.9%)
	(랜섬웨어)	(134, 0.2%)	(124, 20.2%)	(258, 20.2%)	(92, 10.2%)	(103, 10.4%)	(195, 10.3%)	(82, 7.9%)	(192, 14.2%)	(274, 11.5%)
	서버 해킹	320(48.2%)	263(42.9%)	583(45.6%)	504(56.1%)	553(56.0%)	1,057(56.0%)	531(51.4%)	522(38.7%)	1,053(44.2%)
	기타	64(9.6%)	117(19.1%)	181(14.1%)	136(15.1%)	180(18.2%)	316(16.7%)	150(14.5%)	238(17.6%)	388(16.3%)
합 계		664	613	1,277	899	988	1,887	1,034	1,349	2,383

참고 – 2025년 국내 보안 침해사고 동향

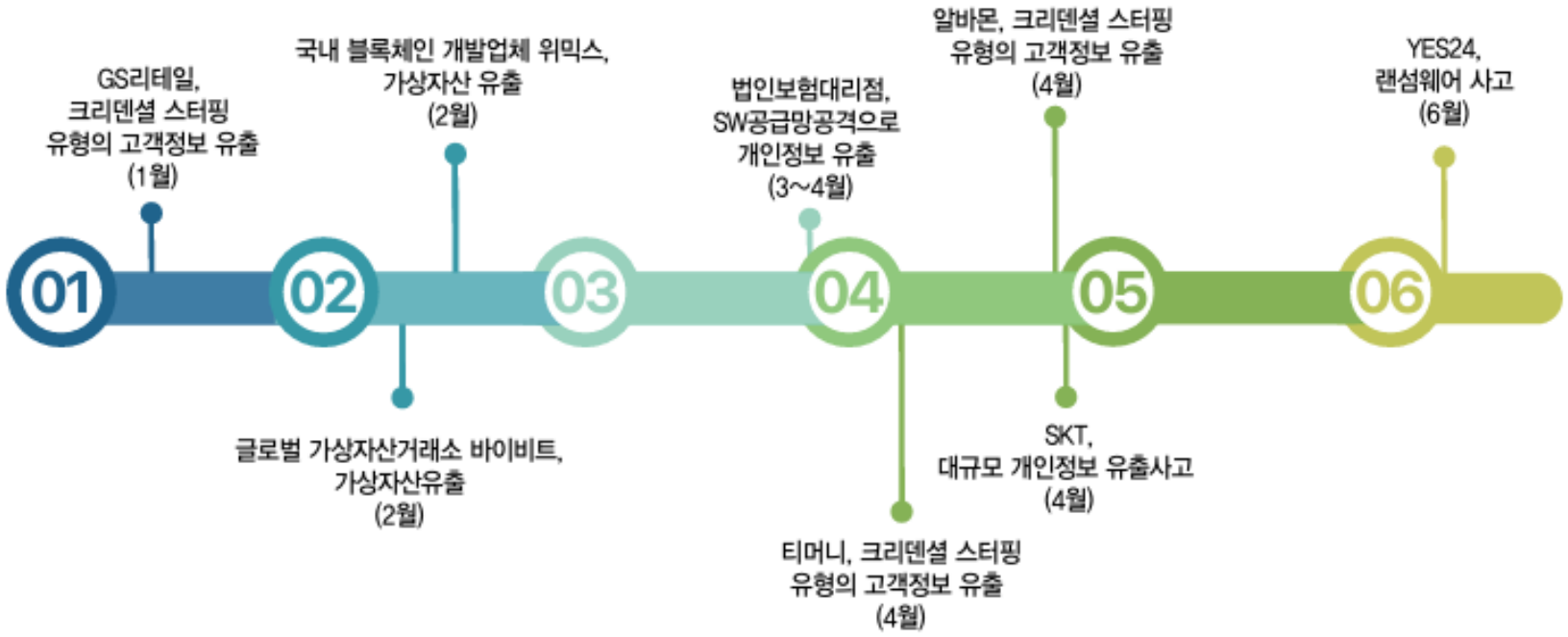


그림 2-1 | 2025년 상반기 월별 주요 침해사고 이슈 동향

※ 출처 : 2025 사이버 위협 동향 보고서(과학기술정보통신부)

참고 – 2025년 국내 보안 침해사고 동향

※ 출처 : 2025 사이버 위협 동향 보고서(과학기술정보통신부)

참고 – 2026년 사이버 위협 전망

※ 출처 : 2025 사이버 위협 동향 보고서(과학기술정보통신부)